UNIVERSIDADE DO VALE DO ITAJAÍ
ESCOLA POLITÉCNICA
CURSO DE CIÊNCIA DA COMPUTAÇÃO
Segurança de Sistemas Computacionais

Diego Fonseca da Silva
Leonardo Pacheco B Dias
Gustavo Gonçalves Trindade
João Victor Rodrigues Santos

# MODELAGEM DE AMEAÇAS NO OWASP JUICE SHOP

TRABALHO 2

Relatório final de modelagem com DFD e STRIDE

Professor Ramicés dos Santos Silva

Itajaí (SC)
Novembro de 2026

# RESUMO

Este trabalho analisa ameaças do OWASP Juice Shop sob a perspectiva de projeto. A aplicação é representada por diagramas de fluxo de dados, com fronteiras de confiança, e examinada com STRIDE por elemento. A análise abrange login e sessão, cadastro e recuperação de senha, cesta e pedido, administração e contabilidade. As ameaças são priorizadas por DREAD e associadas a controles verificáveis do OWASP ASVS, a tipos de fraqueza CWE e à proteção de dados pessoais. As evidências mostram falhas na consulta de autenticação, na composição do JWT e na autorização por objeto. A reexecução do laboratório também reproduziu a atribuição de papel privilegiado no cadastro. O resultado é um plano de mitigação com critérios de aceite para verificar os controles propostos.

Palavras-chave: modelagem de ameaças; DFD; STRIDE; DREAD; OWASP Juice Shop.

# QUADRO DE PARTICIPAÇÃO

| Integrante | Fluxo | Contribuição |
|---|---|---|
| Diego Fonseca da Silva | FX1 | Fundamentação, implantação, atores, ativos e pontos de entrada (C3–C6). |
| Leonardo Pacheco B Dias | FX2 | Inventário e justificativa dos fluxos candidatos (C8). |
| Gustavo Gonçalves Trindade | FX3 | Dependências, premissas, relação com a M1 e revisão de C6 e C8. |
| João Victor Rodrigues Santos | FX4 | Identificação, arquitetura e DFD inicial (C1 e C2). |

# SUMÁRIO

1 INTRODUÇÃO 4

2 FUNDAMENTAÇÃO TEÓRICA 4

2.1 Modelagem de ameaças no ciclo de desenvolvimento seguro . . . . . 4

2.2 DFD e fronteiras de confiança . . . . . 4

2.3 STRIDE por elemento . . . . . 5

2.4 Superfície de ataque e priorização de risco . . . . . 5

2.5 Requisitos de segurança e proteção de dados pessoais . . . . . 6

3 CONTEXTUALIZAÇÃO DO AMBIENTE 6

4 METODOLOGIA 7

5 MODELO DO SISTEMA 7

6 ANÁLISE DOS FLUXOS 9

6.1 FX1: Login e uso da sessão . . . . . 9

6.2 FX2: Cadastro e recuperação de senha . . . . . 15

6.3 FX3: Cesta, checkout e registro do pedido . . . . . 20

6.4 FX4: Administração e contabilidade . . . . . 27

6.5 Justificativas de não aplicabilidade e guias . . . . . 35

7 VISÃO CONSOLIDADA 35

8 VALIDAÇÃO E LIMITAÇÕES 36

9 CONCLUSÃO 37

REFERÊNCIAS 38

# 1 INTRODUÇÃO

No Trabalho 1 a equipe avaliou o OWASP Juice Shop de fora para dentro, encontrando e classificando vulnerabilidades com OWASP, CWE e CVSS. Neste Trabalho 2, a equipe analisa a estrutura do mesmo sistema sob a perspectiva de projeto, respondendo às quatro perguntas de Shostack (2014): o que estamos construindo, o que pode dar errado, o que fazer a respeito e se fizemos um bom trabalho.

O objetivo é identificar e priorizar ameaças em quatro funções da versão v20.2.0 e transformar os cenários de maior risco em requisitos de segurança com critérios de aceite. O documento descreve a fundamentação, a contextualização do ambiente (C1 a C10), a metodologia, o modelo do sistema (DFD), a análise dos quatro fluxos, a visão consolidada e a validação do modelo com comparação ao Trabalho 1.

# 2 FUNDAMENTAÇÃO TEÓRICA

## 2.1 Modelagem de ameaças no ciclo de desenvolvimento seguro

A modelagem de ameaças é a atividade de examinar um sistema, ainda na perspectiva de projeto, para antecipar as condições em que um agente mal-intencionado poderia comprometer seus ativos durante o uso previsto. Em vez de partir de uma falha já observada, como no teste de invasão, ela parte da estrutura do sistema e pergunta, de forma sistemática, onde a confiança é depositada e onde essa confiança pode ser quebrada. No ciclo de vida de desenvolvimento seguro (SSDLC), esse exame é posicionado cedo, porque corrigir uma decisão de projeto é mais barato do que remediar uma vulnerabilidade em produção; o Secure Software Development Framework recomenda, na prática PW.1.1, modelar ameaças e superfícies de ataque e considerar relatórios anteriores de vulnerabilidades como insumo da análise (Souppaya, Scarfone e Dodson, 2022). Neste trabalho, os achados do Trabalho 1 orientam a análise dos pontos cujo comportamento já foi observado.

Shostack (2014) organiza a modelagem em quatro perguntas que estruturam todo este relatório: o que estamos construindo, o que pode dar errado, o que vamos fazer a respeito e se fizemos um bom trabalho. A primeira pergunta é respondida pela documentação do sistema; a segunda, pela identificação sistemática de ameaças; a terceira, pela priorização e pelo tratamento; e a quarta, pela validação do próprio modelo. Tuma, Çalikli e Scandariato (2018), em revisão sistemática, observam que a qualidade de uma análise de ameaças depende menos da técnica isolada e mais do rigor do procedimento e da verificação dos resultados. Por isso, adota-se aqui a distinção explícita entre evidência de execução, inspeção de código e hipótese de ataque, que indica, para cada cenário, que tipo de teste poderia confirmá-lo ou refutá-lo.

## 2.2 DFD e fronteiras de confiança

O Diagrama de Fluxo de Dados (DFD) é a notação escolhida para responder à primeira pergunta. Ele representa quatro tipos de elemento: entidades externas, que fornecem ou recebem dados fora do sistema modelado; processos, que transformam dados; armazenamentos, que os conservam; e fluxos, que transportam a informação entre os demais elementos (Hernan et al., 2006). Cada elemento recebe um identificador único, reutilizado em todas as tabelas do relatório, o que permite rastrear as relações entre o diagrama, as fichas, o registro de ameaças e as mitigações. O DFD descreve por onde os dados passam e onde ficam, e não a sequência de decisões do programa; não é, portanto, um fluxograma.

A fronteira de confiança é o conceito central do diagrama para a segurança: ela marca o ponto em que mudam as garantias com que os dados podem ser usados ou as permissões necessárias para acessá-los. Em cada fluxo que cruza uma fronteira, a análise deve verificar quais dados e permissões precisam ser validados pelo componente de destino. O DFD de contexto (nível 0) concentra a aplicação em um único processo e explicita as entidades externas e as interfaces; o DFD de nível 1 decompõe a operação interna em processos e armazenamentos, com todas as fronteiras relevantes. A análise dos fluxos utiliza recortes do DFD de nível 1.

## 2.3 STRIDE por elemento

STRIDE é o método usado para responder à segunda pergunta, o que pode dar errado. A sigla reúne seis categorias de ameaça, cada uma associada à violação de uma propriedade de segurança, conforme o Quadro 1: Spoofing viola a autenticidade, Tampering a integridade, Repudiation o não repúdio, Information Disclosure a confidencialidade, Denial of Service a disponibilidade e Elevation of Privilege a autorização (Hernan et al., 2006). A classificação orienta o analista a verificar, elemento por elemento, de que modo cada propriedade poderia ser comprometida.

A variante STRIDE por elemento, formalizada pela Microsoft, reconhece que nem toda categoria se aplica a todo tipo de elemento e define o mínimo a analisar em cada um: entidades externas são examinadas quanto a Spoofing e Repudiation; processos, quanto às seis categorias; fluxos e armazenamentos, quanto a Tampering, Information Disclosure e Denial of Service, acrescentando-se Repudiation aos armazenamentos que guardam registros de auditoria. O preenchimento da matriz fornece cobertura de análise, mas não encerra a avaliação: Scandariato, Wuyts e Joosen (2015) mostram que a técnica pode produzir tanto ameaças incorretas quanto omissões, de modo que a verificação de cada cenário depende de sua aderência à rota, ao papel do agente e à evidência disponível. Cada ameaça aceita é reescrita no formato padrão, descrevendo o agente, a ação, o elemento afetado, a fraqueza explorada e o impacto, para evitar enunciados genéricos.

Quadro 1: Categorias STRIDE e propriedades de segurança

| Categoria | Significado | Propriedade |
|---|---|---|
| S: Spoofing | Falsificação de identidade | Autenticidade |
| T: Tampering | Alteração indevida de dados ou lógica | Integridade |
| R: Repudiation | Contestação de autoria sem evidência | Não repúdio |
| I: Information Disclosure | Exposição de informação a agente indevido | Confidencialidade |
| D: Denial of Service | Indisponibilidade ou degradação | Disponibilidade |
| E: Elevation of Privilege | Acesso além da permissão | Autorização |

Fonte: adaptado de Hernan et al. (2006).

## 2.4 Superfície de ataque e priorização de risco

A superfície de ataque compreende o conjunto de canais, métodos e dados por meio dos quais um agente consegue interagir com o sistema. Manadhata e Wing (2011) tratam esses elementos como recursos que contribuem para a exposição: cada rota alcançável, parâmetro, cabeçalho, cookie, token ou arquivo amplia a superfície por permitir uma operação distinta. Mapear a superfície, organizada em categorias como rede, interface de usuário, interface administrativa, integração externa e dados, é condição para que a análise de ameaças seja abrangente, pois cada ponto de entrada é um candidato a ser examinado com STRIDE.

Identificadas as ameaças, é preciso priorizá-las, já que nem todas têm o mesmo risco. Adota-se o DREAD, que decompõe o risco em cinco dimensões, cada uma com nota de 1 a 10: dano potencial, reprodutibilidade, explorabilidade, usuários afetados e facilidade de descoberta (Meier et al., 2003). O risco é a média aritmética das cinco notas, na escala da disciplina (baixo até 3,9; médio de 4,0 a 6,9; alto a partir de 7,0). Por ser um método de julgamento, cada nota é acompanhada de uma justificativa, e os empates são resolvidos por critério explícito. Alves et al. (2024) aplicam STRIDE e DREAD de forma combinada a um sistema IoT, com identificação e priorização em momentos distintos, abordagem semelhante à adotada aqui.

### 2.5 Requisitos de segurança e proteção de dados pessoais

A terceira pergunta de Shostack orienta a definição de mitigações concretas e verificáveis. Para ancorá-las, cada medida é ligada a um requisito do OWASP Application Security Verification Standard (ASVS) 5.0, que fornece requisitos testáveis de autenticação, gestão de sessão e controle de acesso; a um identificador do Common Weakness Enumeration (CWE), que classifica a fraqueza subjacente, mantendo a continuidade com a classificação do Trabalho 1; e, quando há tratamento de dados pessoais, a dispositivos da Lei Geral de Proteção de Dados (LGPD). O art. 46 da LGPD impõe medidas técnicas e administrativas de proteção contra acessos não autorizados, e o princípio da necessidade (art. 6º, III) orienta a minimização de dados em respostas, tokens e logs (Brasil, 2018). Carneiro, Kudo e Bulcão Neto (2024) propõem transformar disposições legais em padrões de requisitos de software, o que sustenta a tradução, neste trabalho, de obrigações da LGPD em critérios de aceite concretos.

# 3 CONTEXTUALIZAÇÃO DO AMBIENTE

O capítulo responde às perguntas C1 a C10 do roteiro. A fundamentação e a contextualização retomam a Etapa 1 em versão revisada, conforme a estrutura do roteiro.

C1–C3 (identificação, arquitetura e implantação).

O OWASP Juice Shop é uma loja fictícia mantida por colaboradores da OWASP. A M1 implantou a imagem oficial bkimminich/juice-shop:v20.2.0 (digest sha256:8739101ade29358abb5469ee66ae78e582c97ed0a5543a4ad102e5fa5193526b). A interface é uma SPA em Angular/TypeScript; o back-end é Node.js com Express expondo JSON, com SQLite acessado por Sequelize, coleções em MarsDB e comprovantes em PDF no diretório ftp/. A autenticação local emite JWT RS256. O Compose publica a porta 3000 apenas em 127.0.0.1, em rede bridge do laboratório, com execução como UID 65532. O host é Windows com Docker Desktop. O Compose usa HTTP, não declara volume nem fixa a sub-rede; o alcance pela bridge e as conexões de saída dependem da configuração da rede. Os pedidos e o estado de entrega ficam na coleção orders de MarsDB (D3); D1 conserva os demais dados relacionais.

Quadro 2: Atores e permissões (C4)

| Ator / papel | Funções e limites |
|---|---|
| E1 / visitante | Sem sessão. Usa cadastro, recuperação, login, catálogo e arquivos públicos. |
| E2 / cliente | Opera a própria cesta e pedidos (customer e deluxe). |
| E3 / admin | Consulta usuários e modera feedbacks; a permissão na API é verificada à parte. |
| E4 / accounting | Consulta pedidos e altera entrega em rotas com verificação de papel. |
| Serviços externos | Google OAuth e chatbot aparecem em configuração, fora do recorte. |

Fonte: OWASP Juice Shop (2026) e Silva et al. (2026).

Quadro 3: Ativos e classificação de dados (C5)

| Conjunto de dados | Classificação (C5) |
|---|---|
| E-mail, nome, endereço, telefone, IP | Dado pessoal quando vinculável a titular identificável. |
| Senha, hash, resposta de segurança, JWT, TOTP | Credenciais/segredos de autenticação. |
| Cesta, pedido, endereço, comprovante | Dado pessoal quando associado à conta. |
| Cartão e carteira (simulação) | Dados de pagamento fictícios no laboratório. |

Fonte: Brasil (2018) e OWASP Juice Shop (2026).

Quadro 4: Superfície de ataque por categoria (C6)

| Categoria (C6) | Entradas e evidência |
|---|---|
| Rede | HTTP TCP 3000 em loopback; Socket.IO integra o servidor (TB-01, TB-02). |
| Interface de usuário | Login, cadastro, recuperação, busca, checkout (M1: login, reset, cesta). |
| Administrativa | /#/administration, /#/accounting e respectivas APIs. |
| Integração externa | Google OAuth, /b2b/v2/orders, /rest/chat (código/config, sem uso na M1). |
| Dados e arquivos | Corpos JSON, cookies, JWT, SQLite e PDFs; /ftp/ comprovado em V5. |

Fonte: OWASP Juice Shop (2026) e Silva et al. (2026).

C7–C9 (dependências, seleção e premissas).

Entre as dependências relevantes estão Express e finale-rest (CRUD e middlewares), Sequelize e sqlite3 (persistência; a consulta bruta de login não usa a proteção do ORM), jsonwebtoken 0.4.0 e express-jwt 0.1.3 (emissão e validação de JWT), express-rate-limit (cota do reset), MarsDB e Socket.IO, e Morgan/serve-index/PDFKit. Foram selecionados quatro fluxos (Quadro 5): FX1 cobre a sessão, FX2 e FX3 tratam dados pessoais e FX4 concentra função privilegiada; todos cruzam ao menos uma fronteira e três contêm achados da M1. Assume-se a integridade do host, do Docker e da rede local; carga, expiração, concorrência e rotas não analisadas ficam fora do escopo. Os dados examinados não abrangem as categorias de dados pessoais sensíveis do art. 5º, II da LGPD; credenciais continuam exigindo proteção específica.

Quadro 5: Fluxos candidatos e critérios de seleção (C8)

| ID | Funcionalidade | Justificativa da seleção |
|---|---|---|
| FX1 | Login e uso da sessão | Sustenta a identidade das demais funções. V1, V2, V6. |
| FX2 | Cadastro e recuperação de senha | Grava dados de conta e expõe a recuperação. V7. |
| FX3 | Cesta, checkout e pedido | Trata dados de compra e comprovante. V3, V4, V5. |
| FX4 | Administração e contabilidade | Função privilegiada sobre vários titulares. |
| FX5 | Login com Google OAuth (reserva) | Depende de provedor externo; não comprovado na M1. |

Fonte: elaboração própria.

C10 (relação com o Trabalho 1).

Quadro 6: Rastreabilidade dos achados da M1 (C10)

| ID | OWASP / CVSS | Efeito observado | Local na M2 |
|---|---|---|---|
| V1 | A03 / 9,1 | SQL injection no login e entrada como admin. | FX1 · T-FX1-02 |
| V2 | A02 / 6,5 | Hash MD5 no payload do JWT. | FX1 · T-FX1-04 |
| V3 | A01 / 6,5 | Cesta da conta A lida com JWT da conta B. | FX3 · T-FX3-06 |
| V4 | A05 / 5,3 | Erro detalhado em rota de cesta. | FX3 · T-FX3-04 |
| V5 | A05 / 7,5 | Listagem e download anônimos em /ftp/. | FX3 · apoio T-FX3-07 |
| V6 | A07 / 6,5 | 15 falhas 401 seguidas de login sem bloqueio. | FX1 · T-FX1-01 |
| V7 | A04 / 9,1 | Pergunta consultável e reset no 5º palpite. | FX2 · T-FX2-01/04 |

Fonte: Silva et al. (2026) e elaboração própria.

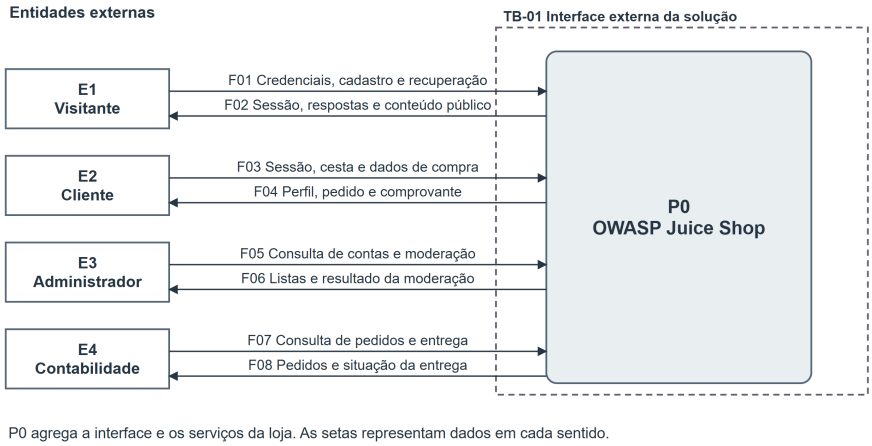
# 4 METODOLOGIA

A análise combinou os documentos e os artefatos da M1, a inspeção do código e dos testes da tag v20.2.0 e a reexecução local de 08/11/2026. E, P, D, F e TB identificam entidades, processos, armazenamentos, transferências e fronteiras; T-FX<n>-<seq> identifica ameaças. Confirmada no T1 designa observação histórica; Plausível designa hipótese ainda sem reprodução. T-FX2-06 conserva o estado histórico no arquivo-fonte e recebe a indicação adicional de reprodução na M2. A média DREAD soma as cinco notas e divide por cinco: baixo até 3,9; médio de 4,0 a 6,9; alto a partir de 7,0. Empates seguem confirmação histórica, dano e ID. Cada nota é justificada, e cada tratamento informa controle, camada, referência, decisão e aceite. Os códigos V1 a V3 do questionário de fechamento são distintos dos achados V1 a V7 da M1.

# 5 MODELO DO SISTEMA

O DFD de contexto (Figura 1) concentra a aplicação em um processo (P0) e suas entidades externas. O DFD de nível 1 (Figura 2) decompõe o serviço Express em processos (P2 identidade, P3 cadastro, P4 cesta, P5 funções privilegiadas, P6 arquivos) e explicita os armazenamentos e as fronteiras de confiança.

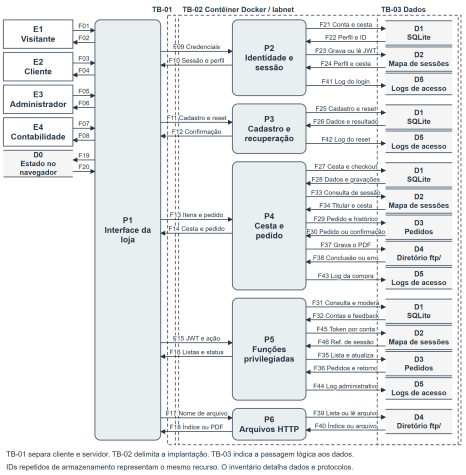
Figura 1: DFD de contexto do OWASP Juice Shop




P0 agrega a interface e os serviços da loja. As setas representam dados em cada sentido.

Fonte: elaboração própria.

Figura 2: DFD de nível 1 com fronteiras de confiança




Fonte: elaboração própria.

Quadro 7: Inventário dos elementos do DFD

| ID | Tipo | Responsabilidade | Tecnologia |
|---|---|---|---|
| P1 | Processo | Interface da loja (SPA) no navegador. | Angular |
| P2 | Processo | Identidade e sessão; emite e valida JWT. | Express, jsonwebtoken |
| P3 | Processo | Cadastro e recuperação de senha. | Express, finale-rest |
| P4 | Processo | Cesta, pedido e comprovante. | Express, MarsDB, PDFKit |
| P5 | Processo | Funções administrativas e contábeis. | Express, finale-rest |
| P6 | Processo | Arquivos HTTP (ftp/). | serve-index, sendFile |
| D1 | Armazenamento | Guarda contas, respostas de segurança, cestas, endereços, cartões, estoque e feedbacks. | SQLite |
| D2 | Armazenamento | Mapa de sessões (JWT→perfil). | Memória Node.js |
| D4 | Armazenamento | Diretório ftp/ (exemplos e comprovantes). | Sistema de arquivos |
| D5 | Armazenamento | Logs de acesso HTTP. | Morgan |
| P0 | Processo | Aplicação de loja fictícia vista como processo único no nível 0. | Angular e Node.js/Express |
| E1 | Entidade externa | Pessoa sem sessão. Inicia cadastro, recuperação e login, e consulta conteúdo público. | Navegador ou cliente HTTP |
| E2 | Entidade externa | Titular de conta customer ou deluxe com sessão. Opera a própria cesta e compra. | Navegador ou cliente HTTP |
| E3 | Entidade externa | Papel admin previsto para consulta de contas e moderação de feedbacks. | Navegador ou cliente HTTP |
| E4 | Entidade externa | Papel accounting previsto para consultar pedidos e modificar o estado de entrega. | Navegador ou cliente HTTP |
| D0 | Armazenamento | Mantém token no localStorage e em cookie, além do ID de cesta no sessionStorage. | Web Storage e cookie |
| D3 | Armazenamento | Guarda coleção de pedidos e estado de entrega em memória. | MarsDB, coleção orders |

Fonte: OWASP Juice Shop (2026) e elaboração própria.

Quadro 8: Fronteiras de confiança

| Fronteira | Lados | Mudança de confiança |
|---|---|---|
| TB-01 | Cliente \| servidor | Dados controlados pelo cliente chegam a rotas que autenticam, autorizam e validam. |
| TB-02 | Host \| contêiner | Encaminhamento da porta do host ao processo; loopback restringe a publicação. |
| TB-03 | Aplicação \| armazenamentos | A requisição passa a leitura/gravação de ativos internos, com permissões do processo. |

Fonte: elaboração própria.

# 6 ANÁLISE DOS FLUXOS

Cada fluxo reúne ficha, transferências, classificação de dados, controles, matriz completa, respostas às 28 perguntas e registro de identificação e tratamento. As notas e justificativas seguem modelo_ameacas.json. A revisão documental final conferiu os quatro fluxos e conciliou os registros com o arquivo-fonte.

## 6.1 FX1: Login e uso da sessão

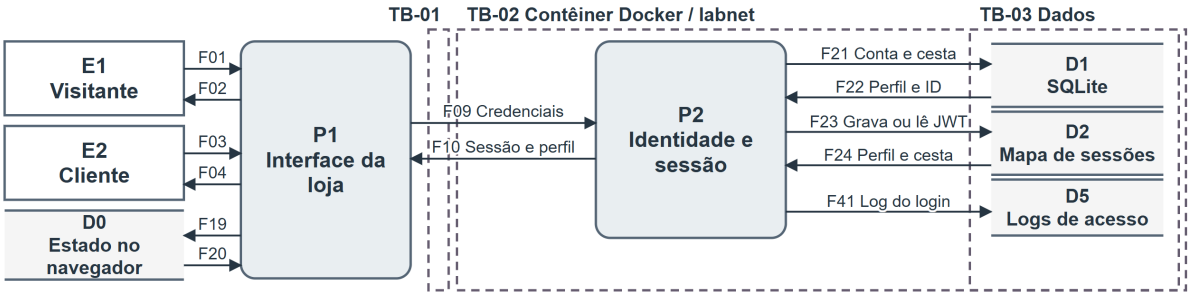
Após enviar e-mail e senha, o cliente recebe uma sessão de compra se a autenticação for bem-sucedida. A SPA armazena o token e o ID de cesta e reutiliza a credencial para identificar a conta e operar as rotas protegidas. O fluxo inclui consulta do perfil e limpeza local de sessão.

Quadro 9: Ficha e dados do FX1

| Campo | Descrição |
|---|---|
| Responsável / revisor | Diego Fonseca da Silva / Gustavo Gonçalves Trindade |
| Ator e gatilho | Visitante E1 ao enviar o formulário de login. O cliente E2 atua depois da emissão. |
| Pré-condições | Conta cadastrada, aplicação acessível e credenciais válidas. O código prevê TOTP quando configurado. O desafio de segundo fator fica fora do recorte principal. |
| Resultado | Token para a conta autenticada, ID de cesta associado e perfil nas chamadas de sessão. Logout remove o estado do navegador. |
| E-mail, ID e IP de acesso | Dado pessoal quando identificável; F09, F10, F21, F22, D1 e D5; propriedade crítica: Confidencialidade. |
| Senha e hash MD5 | Credencial ou segredo; Senha em F09, hash em D1 e observado em F10; propriedade crítica: Confidencialidade. |
| JWT e cookie token | Credencial de sessão; F09, F10, F19, F20, D0 e D2; propriedade crítica: Confidencialidade. |
| Papel e vínculo de cesta | Interno e dado pessoal vinculado; D1, D2, F10 e D0; propriedade crítica: Integridade. |
| Controle: P2, F09 e F10 | Assinatura RS256 em emissão e verificação em rotas protegidas. Base: Código e JWT preservado em V1 e V2. |
| Controle: P2 | Resposta inválida HTTP 401 e TOTP condicional. Base: V6 e routes/login.ts. O segundo fator não foi exercitado na M1. |
| Controle: P2, D1 | Hash de senha e filtro de conta excluída. Base: routes/login.ts, models/user.ts e V2. O hash é MD5 sem sal. |
| Controle: D5, F41 | Registro HTTP com rotação. Base: server.ts. Evidência de configuração, sem verificação de proteção do arquivo. |

Fonte: elaboração própria.

Figura 3: Recorte do DFD do FX1




Fonte: elaboração própria.

Quadro 10: Requisições e base de observação do FX1

| Método e rota | Base e observação |
|---|---|
| POST /rest/user/login | M1 V1, V2 e V6. Requisição de login, emissão e série de falhas. |
| GET /rest/user/whoami | Código v20.2.0. routes/currentUser.ts. Cookie token e parâmetro fields. |
| GET /rest/basket/:id | M1 V3, chamada protegida de apoio. Requisição sem token recusada e com token válida para acesso. O objeto é analisado no FX3. |

Fonte: elaboração própria.

Quadro 11: Transferências de dados do FX1

| F | Origem > destino | Dados | Protocolo / fronteira |
|---|---|---|---|
| F01 | E1 > P1 | Credenciais, cadastro, recuperação, navegação e arquivos públicos | Interface web / formulário; sem travessia |
| F02 | P1 > E1 | Formulários, identidade inicial e respostas públicas | Interface web / renderização; sem travessia |
| F03 | E2 > P1 | Ações autenticadas de sessão, cesta e compra | Interface web / formulário; sem travessia |
| F04 | P1 > E2 | Perfil, itens, estado de compra e comprovante | Interface web / renderização; sem travessia |
| F09 | P1 > P2 | E-mail e senha, cookie ou JWT Bearer | HTTP / JSON; TB-01, TB-02 |
| F10 | P2 > P1 | JWT, ID de cesta, perfil e erros | HTTP / JSON; TB-01, TB-02 |
| F19 | P1 > D0 | JWT, cookie e ID da cesta | Web Storage / cookie; sem travessia |
| F20 | D0 > P1 | JWT e ID da cesta para requisições | Web Storage / cookie; sem travessia |
| F21 | P2 > D1 | Consulta de credenciais e busca ou criação da cesta | Sequelize / SQL local; TB-03 |
| F22 | D1 > P2 | Modelo da conta e ID da cesta | Sequelize / SQL local; TB-03 |
| F23 | P2 > D2 | Gravação ou consulta por JWT | Acesso em memória; TB-03 |
| F24 | D2 > P2 | Perfil, ID da cesta ou ausência de sessão | Acesso em memória; TB-03 |
| F41 | P2 > D5 | Método, URL, horário, origem e status de autenticação HTTP | Escrita local / log HTTP; TB-03 |

Fonte: elaboração própria.

Quadro 12: Matriz STRIDE completa do FX1

| Elemento | S | T | R | I | D | E |
|---|---|---|---|---|---|---|
| D0 | | N/A 11 | | 04 | N/A 10 | |
| D1 | | N/A 7 | | N/A 7 | N/A 6 | |
| D2 | | N/A 7 | | 04 | 05 | |
| D5 | | N/A 9 | 03 | N/A 9 | N/A 9 | |
| E1 | 01 | | 03 | | | |
| E2 | N/A 1 | | 03 | | | |
| P1 | N/A 8 | N/A 13 | N/A 8 | 04 | N/A 10 | N/A 8 |
| P2 | 01 | 02 | 03 | 04 | 05 | 06 |
| F01 | | N/A 13 | | N/A 13 | N/A 6 | |
| F02 | | N/A 13 | | N/A 13 | N/A 6 | |
| F03 | | N/A 13 | | N/A 13 | N/A 6 | |
| F04 | | N/A 13 | | N/A 13 | N/A 6 | |
| F09 | | 02 | | N/A 4 | 05 | |
| F10 | | N/A 3 | | 04 | N/A 6 | |
| F19 | | N/A 11 | | 04 | N/A 6 | |
| F20 | | N/A 11 | | 04 | N/A 6 | |
| F21 | | 02 | | N/A 4 | N/A 6 | |
| F22 | | N/A 3 | | N/A 4 | N/A 6 | |
| F23 | | N/A 3 | | N/A 4 | 05 | |
| F24 | | N/A 3 | | N/A 4 | N/A 6 | |
| F41 | | N/A 9 | | N/A 9 | N/A 6 | |

Fonte: elaboração própria.

Na matriz, 01 significa T-FX1-01, e assim sucessivamente. Célula vazia: categoria inaplicável ao tipo. Os códigos N/A remetem às justificativas após os quatro fluxos.

## Questionário do fluxo

Compreensão. Q1: FX1 autentica contas para compras e operações privilegiadas. Falhas em P2 ampliam outras ameaças, como a sessão administrativa de T-FX1-02. Q2: E1 fornece credenciais; E2 usa a sessão emitida. Admin e accounting compartilham o login, com funções específicas analisadas em FX4. Q3: E1 aciona P1/F01; P2 recebe HTTP/JSON (F09/F10), consulta SQLite/D1 (F21/F22) e memória/D2 (F23/F24), registra D5/F41 e usa D0 via F19/F20. Q4: F09/F10 cruzam TB-01/TB-02; F21-F24/F41 cruzam TB-03. Dados do cliente passam à consulta interna, onde o e-mail exige parametrização. Q5: E-mail, ID e IP vinculável são pessoais; senha, hash e JWT são segredos. D1 guarda hash; D0/D2, sessão. Não se identificaram dados sensíveis nos campos examinados. Q6: Corpo JSON, Authorization, cookie token e fields de whoami são entradas de interface/API; localStorage e sessionStorage integram a superfície do navegador. Q7: V6 mostra recusa de senha incorreta; a M1 confirmou JWT assinado e MD5. Código: assinatura, TOTP condicional, mapa e log; Compose: HTTP/loopback.

Falsificação de identidade. S1: P2 compara senha com D1; rotas protegidas usam JWT, e whoami usa cookie/mapa. SQLite é biblioteca local, sem autenticação de rede. S2: P2 emite JWT RS256; SPA guarda em localStorage e cookie de oito horas, enviando Bearer. Validação por assinatura/mapa conforme rota. expiresIn diverge de expiresInMinutes na biblioteca 0.4.0; V1/V2 omitem exp. Novo login emite outro; logout limpa D0, sem revogação identificada. S3: T-FX1-01 considera tentativas sem bloqueio na amostra; T-FX1-06, falsificação pela chave fixa. A M1 confirmou login administrativo sem senha correta por injeção.

Adulteração. T1: O cliente controla P1/D0 e pode alterar o e-mail antes de F09/F21. Modificar SQLite diretamente exige acesso ao host, excluído do recorte. T2: P2 calcula hash e consulta conta não excluída; interpola e-mail no SQL, vulnerável em V1. Rotas consumidoras precisam autorizar cada objeto. T3: RS256 protege JWT quando assinatura e chave são verificadas. HTTP local não fornece TLS; MD5 não protege transporte nem corrige interpolação.

Repúdio. R1: F41 registra método, URL, data, status, origem e agente de usuário. Morgan combined não reúne conta e sessão no evento de autenticação. R2: D5 é local, com rotação diária e retenção de dois dias; a inspeção não identificou coleta separada nem imutabilidade para F41. R3: Em T-FX1-03, alguém pode negar autenticação ou tentativa quando o log não liga origem aparente, conta, sessão e resultado do controle.

Divulgação de informação. I1: V2 mostra hash/perfil no JWT de F10. whoami aceita fields sem lista de permissão identificada; teste upstream também consulta password. I2: P1 precisa de identificação, estado de autenticação e dados de interface. Serializar a conta no JWT inclui password, desnecessário à sessão. I3: HTTP local não fornece TLS. SQLite guarda hash; JWT é legível e permanece em D0. Cifragem de arquivo e gestão isolada da chave não foram demonstradas.

Disponibilidade. D1: Login consome consultas de conta/cesta, CPU e memória de emissão e mapa D2. O esgotamento por volume de T-FX1-05 não foi medido. D2: O parser limita corpos; quinze falhas em V6 não bloquearam login. Não foram identificados limitador próprio, tamanho máximo ou expurgo do mapa. D3: Login por senha depende de SQLite, Node.js e configuração locais; a indisponibilidade desses componentes afeta o fluxo, que dispensa Google/provedor externo.

Elevação de privilégio. E1: P2 autentica; cada rota consumidora precisa verificar token e permissão do recurso. A assinatura isolada não autoriza papel, objeto ou campo. E2: V1 confirmou acesso administrativo pelo login. T-FX1-06 considera forja com chave distribuída; FX3/FX4 analisam os recursos com verificações distintas. E3: O Dockerfile define UID 65532; SQLite e mapa usam o processo Node.js. Privilégios efetivos não foram verificados por inspeção do contêiner.

Fechamento. V1: T-FX1-02 (9,8) permite obter identidade administrativa por entrada anônima, com alcance sobre dados e funções de outros titulares da instância. V2: M1: V1/T-FX1-02, V2/T-FX1-04 e V6/T-FX1-01. M2 reproduziu SQLi e hash no JWT, sem exp. Esgotamento, atribuição incompleta e exploração da chave permanecem hipóteses. V3: A revisão documental foi concluída. Verificação temporal por rota, recuperação com TOTP e comportamento após logout não foram testados; o recorte usa senha.

Quadro 13: Registro de ameaças do FX1, identificação

| ID / elementos | Categoria / propriedade / classificação | Cenário e evidência |
|---|---|---|
| T-FX1-01<br>P2, E1 | S / Autenticidade<br>CWE-307 / A07<br>Confirmada no T1 (V6) | Um visitante E1 pode repetir palpites de senha em P2 pelo fluxo F09, explorando a ausência de contenção efetiva na sequência observada. Se acertar uma senha fraca, passa a se apresentar como o titular da conta.<br>Base: V6. HTTP 401 nas 15 tentativas incorretas e HTTP 200 no login correto em seguida. |
| T-FX1-02<br>P2, F09, F21 | T / Integridade<br>CWE-89 / A03<br>Confirmada no T1 (V1) | Um visitante E1 pode alterar a lógica da consulta de autenticação em P2 e F21 enviando entrada controlada em F09. A concatenação do e-mail ao SQL permite ignorar o predicado de senha e iniciar uma sessão administrativa, com acesso a dados e ações reservadas.<br>Base: V1. A M1 registrou bypass do login administrativo e confirmação booleana pelo sqlmap. |
| T-FX1-03<br>D5, P2, E1, E2 | R / Não repúdio<br>CWE-778 / A09<br>Plausível | Um agente que obtenha uma sessão em P2 pode negar a autoria da autenticação ou atribuí-la a outra pessoa. Em F41 e D5, o log de acesso com origem e horário permite ver a chamada, mas não associa de forma inequívoca tentativa, conta, sessão e resultado.<br>Base: server.ts, middleware Morgan. O formato HTTP combinado não carrega o identificador autenticado emitido no evento. |
| T-FX1-04<br>F10, P1, P2, D0, D2, F19, F20 | I / Confidencialidade<br>CWE-522, CWE-916 / A02<br>Confirmada no T1 (V2) | Um agente com acesso a um token de F10 ou D0 pode ler o campo password do perfil serializado no JWT. O token assinado contém o hash MD5 sem sal da senha, permitindo tentativa de recuperação offline e eventual acesso indevido à conta do titular.<br>Base: V2. JWT de conta de teste decodificado com campo password e resumo MD5 conferido. |
| T-FX1-05<br>D2, P2, F09, F23 | D / Disponibilidade<br>CWE-400 / A04<br>Plausível | Um cliente com credenciais válidas pode emitir sessões repetidamente em P2 e alimentar D2 explorando a falta de limite explícito de entradas e expurgo no mapa. Com volume suficiente, o processo pode degradar a autenticação e o atendimento das demais rotas.<br>Base: routes/login.ts e lib/insecurity.ts. O mapa em memória é preenchido em login e o caminho de emissão não define limite por conta. |
| T-FX1-06<br>P2 | E / Autorização<br>CWE-321 / A02<br>Plausível | Um agente com acesso ao código da versão pode tentar apresentar um JWT privilegiado às rotas que confiam na chave de P2. A chave privada embutida compromete a separação entre emissor e cliente e pode permitir que o agente se atribua um papel reservado.<br>Base: lib/insecurity.ts contém material de assinatura fixo da demonstração. A verificação no laboratório foi documental. |

Fonte: elaboração própria.

Quadro 14: Registro de ameaças do FX1, tratamento

| ID / DREAD / risco | Controle existente | Mitigação, camada, referência e aceite |
|---|---|---|
| T-FX1-01<br>8, 8, 9, 7, 8<br>8,0 / Alto<br>Mitigar | A mensagem de credenciais inválidas retorna HTTP 401. A amostra de V6 permaneceu sem bloqueio. | Aplicar atraso progressivo por conta e origem, registrar tentativas distribuídas e exigir segundo fator nas contas privilegiadas. Evitar bloqueio permanente imposto por terceiros.<br>Preventivo e detectivo / aplicação. ASVS 5.0.0: 6.1.1, 6.3.1; guia AUTH; LGPD, art. 46.<br>Aceite: Em conta de teste, a série configurada deve acionar atraso ou contenção. Uma segunda conta legítima deve continuar acessível. |
| T-FX1-02<br>10, 10, 10, 10, 9<br>9,8 / Alto<br>Mitigar | A aplicação calcula hash da senha e filtra contas apagadas. O e-mail continua interpolado na consulta SQL. | Buscar a conta por e-mail com parâmetros vinculados e verificar a senha em operação separada. Aplicar a mesma regra a entradas do login e manter validação de tipo e tamanho.<br>Preventivo / aplicação e dados. ASVS 5.0.0: 1.2.4; guia SQLI; LGPD, art. 46.<br>Aceite: A entrada usada em V1 deve receber falha genérica de autenticação, sem JWT. O login com credenciais válidas deve continuar funcionando. |
| T-FX1-03<br>6, 7, 7, 6, 6<br>6,4 / Médio<br>Mitigar | O registro HTTP documenta requisição, origem aparente, horário, status e agente de usuário. | Emitir evento estruturado para sucesso, falha e encerramento. Correlacionar ID interno, horário, origem validada, resultado e referência de sessão sem gravar senha ou token integral. Enviar a destino separado.<br>Detectivo / aplicação e processo. ASVS 5.0.0: 16.2.1, 16.3.1, 16.4.2; guia LOG; LGPD, art. 46.<br>Aceite: Verificar três eventos correlacionados no destino e confirmar que o serviço de loja não pode alterar entradas já gravadas. |
| T-FX1-04<br>8, 10, 8, 8, 9<br>8,6 / Alto<br>Mitigar | A assinatura RS256 protege a integridade do token. O campo password está incluído no objeto serializado. | Emitir JWT com um conjunto explícito de claims, sem o modelo de usuário. Migrar MD5 para Argon2id com sal único e custo calibrado, invalidar os tokens antigos e redefinir credenciais expostas quando aplicável.<br>Preventivo e corretivo / aplicação e dados. ASVS 5.0.0: 14.1.1, 14.2.6, 11.4.1; guia PASS; LGPD, art. 46.<br>Aceite: Inspecionar JWT, login e whoami com fields. Nenhuma resposta deve incluir hash, segredo TOTP ou outros campos reservados. |
| T-FX1-05<br>7, 6, 7, 8, 6<br>6,8 / Médio<br>Mitigar | O analisador de corpo limita o tamanho por requisição. O código do mapa não documenta TTL nem capacidade. | Limitar sessões por conta, expurgar entradas expiradas, limitar taxa de login por conta e origem e medir uso do mapa e latência da rota.<br>Preventivo e detectivo / aplicação. ASVS 5.0.0: 2.4.1, 7.1.2; guia SESS; LGPD, art. 46.<br>Aceite: Teste local com carga limitada deve demonstrar memória estabilizada, expurgo das entradas e atendimento das chamadas legítimas. |
| T-FX1-06<br>10, 7, 8, 9, 8<br>8,4 / Alto<br>Mitigar | O middleware verifica a assinatura em rotas protegidas. O material de assinatura está na distribuição do laboratório. | Provisionar chave exclusiva por implantação em gestor de segredos, rotacionar o material, revogar tokens antigos e fixar algoritmo, emissor, audiência, tipo e expiração no verificador.<br>Preventivo e corretivo / aplicação e operação. ASVS 5.0.0: 9.1.2, 13.3.1, 13.3.4; guia SECRETS; LGPD, art. 46.<br>Aceite: Tokens com chave antiga, algoritmo inesperado ou claims inválidas devem ser recusados. O repositório e a imagem não devem conter chave privada ativa. |

Fonte: elaboração própria.

Nas notas DREAD, a ordem é dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta. As justificativas abaixo seguem essa ordem.

Quadro 15: Justificativas das notas do FX1

| ID | Justificativa de cada dimensão |
|---|---|
| T-FX1-01 | Dano (8): Uma senha acertada abre acesso a dados e ações da conta. Reprodutibilidade (8): A sequência de falhas foi reproduzida no T1. Explorabilidade (9): Uma requisição repetida ao login dispensa sessão prévia. Usuários (7): Contas com senhas previsíveis são as mais expostas. Descoberta (8): O formulário e a rota de autenticação são públicos. |
| T-FX1-02 | Dano (10): O bypass administrativo pode atingir dados de vários titulares e funções privilegiadas. Reprodutibilidade (10): O T1 preservou requisição e resposta do bypass. Explorabilidade (10): O caminho observado exige apenas acesso anônimo à rota e um cliente HTTP. Usuários (10): O papel obtido permite alcançar operações com alcance coletivo. Descoberta (9): A rota é pública e a consulta vulnerável consta do código. |
| T-FX1-03 | Dano (6): A deficiência retarda resposta e investigação de contas comprometidas. Reprodutibilidade (7): A estrutura do log é fixa e se repete em cada chamada. Explorabilidade (7): A disputa exige um acesso ou tentativa seguida de investigação. Usuários (6): Cada evento sem correlação pode afetar um titular. Descoberta (6): É preciso conhecer o formato dos registros ou investigá-los. |
| T-FX1-04 | Dano (8): O resumo exposto permite testar senhas sem passar pelo servidor. Reprodutibilidade (10): O T1 confirmou a presença do campo com uma conta própria. Explorabilidade (8): Ler o payload exige o token, e a busca de senha depende da sua força. Usuários (8): A mesma estrutura do JWT é usada em diferentes contas. Descoberta (9): Os campos do JWT são visíveis por decodificação Base64url. |
| T-FX1-05 | Dano (7): O processo de autenticação é compartilhado com a loja. Reprodutibilidade (6): A taxa e a duração necessárias para degradação dependem dos recursos locais. Explorabilidade (7): Uma conta válida basta para gerar novas entradas ao longo do tempo. Usuários (8): A saturação do Node.js pode afetar todas as contas na instância. Descoberta (6): O crescimento do mapa exige inspeção de código ou instrumentação. |
| T-FX1-06 | Dano (10): Um JWT aceito com papel privilegiado afeta operações administrativas. Reprodutibilidade (7): O efeito depende das verificações específicas da rota e não foi ensaiado no T1. Explorabilidade (8): O agente precisa conhecer a estrutura do token e produzir assinatura compatível. Usuários (9): A chave é compartilhada entre contas da instância de demonstração. Descoberta (8): O material está presente no código versionado. |

Fonte: elaboração própria.

### Conclusão e risco residual

A primeira correção incide na consulta de credenciais. Mesmo após parametrizá-la, as sessões ainda dependeriam de chaves e claims adequadas. A retirada de hash do token reduz exposição, enquanto a migração da senha e a revogação de tokens antigos limitam o efeito do material já emitido. Risco residual esperado após o tratamento decorre de credenciais já comprometidas ou reutilizadas, abuso distribuído e roubo de sessão antes da expiração. A mitigação requer verificar o caminho normal de login, os casos negativos e o reaproveitamento de token após encerramento.

## 6.2 FX2: Cadastro e recuperação de senha

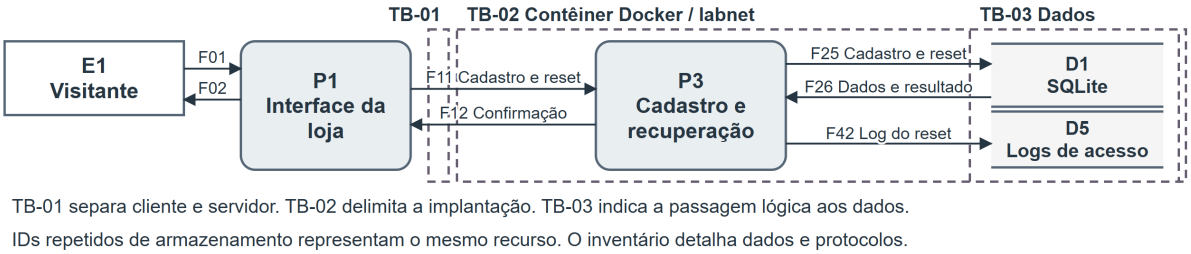
O visitante cria uma conta e escolhe a pergunta de segurança da demonstração. A interface envia uma segunda requisição que associa a resposta ao ID criado. Na recuperação, o visitante consulta a pergunta vinculada ao e-mail e envia a resposta com a nova senha.

Quadro 16: Ficha e dados do FX2

| Campo | Descrição |
|---|---|
| Responsável / revisor | Leonardo Pacheco B Dias / Diego Fonseca da Silva |
| Ator e gatilho | Visitante E1 no envio do cadastro ou na opção de senha esquecida. |
| Pré-condições | Para cadastro, e-mail válido e aplicação acessível. Para recuperação, conta e pergunta de segurança previamente associada. |
| Resultado | Conta criada com papel de cliente e recuperação que altera somente a conta correspondente à prova apresentada. |
| E-mail e ID de usuário | Dado pessoal quando identificável; F11, F12, D1 e possivelmente F42; propriedade crítica: Confidencialidade. |
| Pergunta e vínculo com conta | Dado pessoal quando associado; F11, F12, F25, F26 e D1; propriedade crítica: Confidencialidade. |
| Resposta e senha nova | Credenciais ou segredos; F11, HMAC e hash em D1; propriedade crítica: Confidencialidade. |
| Papel e estado de cadastro | Interno e dado pessoal vinculado; F12, F25 e D1; propriedade crítica: Integridade. |
| Controle: P3 e D1 | Unicidade de e-mail e de UserId na resposta. Base: models/user.ts e models/securityAnswer.ts. A M1 registrou HTTP 400 em tentativa de segunda resposta. |
| Controle: P3, F25 e D1 | HMAC da resposta e hash da senha. Base: routes/resetPassword.ts e modelos. A chave HMAC da demonstração está no código. |
| Controle: P3 e F11 | Limite de 100 solicitações em cinco minutos no reset. Base: Cabeçalhos de V7 e server.ts. A cota não foi esgotada na evidência. |
| Controle: P3 | Verificação de senha nova e repetição. Base: routes/resetPassword.ts. O código rejeita vazio ou divergência. |

Fonte: elaboração própria.

Figura 4: Recorte do DFD do FX2




Fonte: elaboração própria.

Quadro 17: Requisições e base de observação do FX2

| Método e rota | Base e observação |
|---|---|
| POST /api/Users e POST /api/SecurityAnswers/ | M1 V7 e código. Registro de usuário e associação separada. A M1 testou chamadas sem vínculo e com ID explícito. |
| GET /api/SecurityQuestions | Código v20.2.0. Consulta ao catálogo de perguntas para o formulário. |
| GET /rest/user/security-question?email=… | M1 V7. Retorno da pergunta de conta sintética no histórico HTTP. |
| POST /rest/user/reset-password | M1 V7. Quatro falhas e sucesso na quinta tentativa. registro HTTP de V7. Login posterior pertence a FX1. |

Fonte: elaboração própria.

Quadro 18: Transferências de dados do FX2

| F | Origem > destino | Dados | Protocolo / fronteira |
|---|---|---|---|
| F01 | E1 > P1 | Credenciais, cadastro, recuperação, navegação e arquivos públicos | Interface web / formulário; sem travessia |
| F02 | P1 > E1 | Formulários, identidade inicial e respostas públicas | Interface web / renderização; sem travessia |
| F11 | P1 > P3 | Cadastro, IDs, e-mail, resposta e nova senha | HTTP / JSON; TB-01, TB-02 |
| F12 | P3 > P1 | Confirmações de cadastro, pergunta e resultado do reset | HTTP / JSON; TB-01, TB-02 |
| F25 | P3 > D1 | Conta, pergunta, HMAC da resposta e hash de nova senha | Sequelize / SQL local; TB-03 |
| F26 | D1 > P3 | Modelos, pergunta e resultado da gravação | Sequelize / SQL local; TB-03 |
| F42 | P3 > D5 | Método, URL inclusive query string, origem, horário e status de cadastro ou reset | Escrita local / log HTTP; TB-03 |

Fonte: elaboração própria.

Quadro 19: Matriz STRIDE completa do FX2

| Elemento | S | T | R | I | D | E |
|---|---|---|---|---|---|---|
| D1 | | 02 | | N/A 7 | 05 | |
| D5 | | N/A 9 | 03 | N/A 9 | N/A 9 | |
| E1 | 01 | | 03 | | | |
| P1 | N/A 8 | N/A 13 | N/A 8 | 04 | N/A 10 | N/A 8 |
| P3 | 01 | 02 | 03 | 04 | 05 | 06 |
| F01 | | N/A 13 | | N/A 13 | N/A 6 | |
| F02 | | N/A 13 | | N/A 13 | N/A 6 | |
| F11 | | 02 | | N/A 4 | 05 | |
| F12 | | N/A 3 | | 04 | N/A 6 | |
| F25 | | 02 | | N/A 4 | 05 | |
| F26 | | N/A 3 | | N/A 4 | N/A 6 | |
| F42 | | N/A 9 | | 04 | N/A 6 | |

Fonte: elaboração própria.

Na matriz, 01 significa T-FX2-01, e assim sucessivamente. Célula vazia: categoria inaplicável ao tipo. Os códigos N/A remetem às justificativas após os quatro fluxos.

## Questionário do fluxo

Compreensão. Q1: FX2 cria contas e recupera acesso. Resposta previsível em P3 permite substituir a senha de outro titular, como em T-FX2-01. Q2: E1 inicia cadastro/reset sem sessão; a SPA associa após cadastro. JWT usado na associação da M1 não demonstra autenticação universalmente exigida nessa rota. Q3: E1 aciona P1/F01; P3 recebe HTTP com JSON/query string (F11/F12), lê/grava SQLite/D1 (F25/F26) e registra metadados de acesso em D5/F42. Q4: F11/F12 cruzam TB-01/TB-02; F25/F26/F42 cruzam TB-03, convertendo dados do cliente em registros persistidos de conta, recuperação e acesso no servidor. Q5: E-mail/ID são pessoais; senha/resposta são segredos. D1 guarda conta e recuperação. Pergunta vinculada é pessoal; dados sensíveis dependem do conteúdo livre efetivo. Q6: Na interface/API, JSON expõe role, UserId, SecurityQuestionId e answer/new/repeat no reset; e-mail em query string também pode aparecer em logs. Q7: Código aplica unicidade, HMAC, hash e validação básica da senha. V7: quatro recusas, um sucesso, cota informada e segunda associação recusada.

Falsificação de identidade. S1: P3 compara a resposta com HMAC em D1 para o e-mail; cadastro não comprova posse do endereço. SQLite é acessado localmente. S2: A recuperação usa conhecimento persistente, sem credencial de uso único identificada. Após novo login, JWT segue emissão, transporte, validação e limpeza do FX1. S3: T-FX2-01 depende de conhecer/adivinhar resposta alheia; T-FX2-02 considera associação de conta incompleta por dados controlados pelo solicitante, sem confirmação desse efeito.

Adulteração. T1: Campos e IDs podem mudar antes de F11; P3 persiste a conta em D1. Papel e vínculo da resposta exigem controle pelo servidor. T2: P3 valida parte dos campos; D1 impõe unicidade. Cadastro recebe campos do corpo, e resposta de segurança é gravada separadamente com UserId explícito. T3: HMAC protege comparação em D1, sem aumentar entropia; sua chave é distribuída. O fluxo usa HTTP, e o esquema aceita papéis do modelo.

Repúdio. R1: F42 registra cadastro/reset com horário, método, URL, origem e status; não se demonstrou vínculo entre solicitação e posse de canal do titular. R2: D5 tem retenção limitada por rotação, sem proteção demonstrada contra edição privilegiada; audit.json pertence ao rotator, sem constituir auditoria da aplicação. R3: Em T-FX2-03, alguém pode negar a troca de senha: o e-mail alvo identifica a conta solicitada, sem identificar o autor da ação.

Divulgação de informação. I1: V7 expõe pergunta em F12 e password com hash na resposta 200 do reset. Query string pode registrar e-mail em logs/histórico. I2: Um reset por canal verificado dispensa consulta pública da pergunta; confirmar a troca exige informar o resultado, sem devolver o modelo completo. I3: HTTP local transporta F11/F12; D1 guarda hash e HMAC, sujeitos às limitações documentadas. Cifragem do arquivo SQLite em repouso não foi demonstrada.

Disponibilidade. D1: Criar conta, carteira e resposta grava no SQLite; automação pode pressionar o processo compartilhado com outras rotas, conforme a hipótese T-FX2-05. D2: Reset limita 100 pedidos/cinco minutos por chave derivada de IP; cadastro fica fora. Proxy e pedido 101 não foram testados na M1. D3: O mecanismo depende de Express/SQLite locais. A recuperação proposta por canal externo verificado exige política de disponibilidade e limites de reenvio.

Elevação de privilégio. E1: P3 consulta conta/resposta no reset; cadastro deve impor papel mínimo no servidor, e associação deve usar identidade vinculada à transação. E2: V7 confirmou tomada de conta na M1; a reexecução M2 confirmou T-FX2-06, com role:admin enviado pelo cliente e aceito no cadastro. E3: P3 compartilha processo/identidade com outros módulos e escreve conta/resposta no SQLite; menor privilégio exige limitar operações e campos por serviço.

Fechamento. V1: T-FX2-06 tem média 9,0 e permite criar conta privilegiada por um campo do cadastro. O cenário foi reproduzido na M2. V2: T-FX2-01 e T-FX2-04 se apoiam em V7 da M1. T-FX2-06 foi reproduzida em 08/11/2026; as demais hipóteses aguardam ensaio. V3: A revisão documental foi concluída. Associação em conta incompleta, alcance do limitador, tratamento de proxy e invalidação de sessões após reset não foram testados.

Quadro 20: Registro de ameaças do FX2, identificação

| **ID / elementos** | **Categoria / propriedade / classificação** | **Cenário e evidência** |
|---|---|---|
| T-FX2-01<br>P3, E1 | S / Autenticidade<br>CWE-640 / A04<br>Confirmada no T1 (V7) | Um visitante E1 pode redefinir a senha de uma conta em P3 por F11 se adivinhar sua resposta de segurança. A recuperação baseada em conhecimento previsível aceita o palpite correto dentro da janela observada, permitindo assumir a conta sem a senha anterior.<br>Base: V7. Resposta previsível aceita na quinta tentativa e login posterior com a nova senha. |
| T-FX2-02<br>P3, F11, F25, D1 | T / Integridade<br>CWE-639, CWE-862 / A01<br>Plausível | Um visitante E1 pode tentar vincular uma resposta própria a uma conta ainda sem associação em P3 e D1. O POST separado carrega o UserId fornecido pelo cliente. Se o servidor aceitar um ID alheio elegível, o agente passa a controlar o dado usado na recuperação dessa conta.<br>Base: server.ts, models/securityAnswer.ts e register.component.ts. V7 registrou UserId nulo sem associação e HTTP 400 para sobrescrita já existente. |
| T-FX2-03<br>D5, P3, E1 | R / Não repúdio<br>CWE-778 / A09<br>Plausível | Um agente que solicite reset em P3 pode negar sua participação após trocar a senha de outra pessoa. Em F42 e D5, método, status e endereço de origem não estabelecem o vínculo entre a operação, o titular, a prova de recuperação e a alteração de estado.<br>Base: routes/resetPassword.ts e server.ts. A resposta do reset e o log HTTP não identificam quem apresentou o conhecimento secreto. |
| T-FX2-04<br>F12, P3, P1, F42 | I / Confidencialidade<br>CWE-203, CWE-598 / A07<br>Confirmada no T1 (V7) | Um visitante E1 pode consultar P3 com um e-mail e obter em F12 a pergunta vinculada, explorando a diferença de resposta do endpoint. Isso revela uma associação de recuperação e fornece contexto para atacar a conta. O e-mail em query string também pode aparecer em F42.<br>Base: V7. Consulta anônima retornou a pergunta associada. routes/securityQuestion.ts distingue resposta com pergunta e objeto vazio. |
| T-FX2-05<br>P3, D1, F11, F25 | D / Disponibilidade<br>CWE-400 / A04<br>Plausível | Um visitante E1 pode submeter cadastros em sequência para P3 e acumular registros em D1. A criação pública de conta e carteira sem orçamento específico identificado pode ocupar escrita no SQLite, CPU e disco, degradando cadastro e recuperação.<br>Base: server.ts e fluxo do cadastro. Criação de usuário e carteira, com resposta de segurança em operação separada. |
| T-FX2-06<br>P3 | E / Autorização<br>CWE-915, CWE-269 / A01<br>Plausível na análise inicial; reproduzida na M2 (08/11/2026) | Um visitante E1 pode tentar enviar role privilegiado no cadastro em F11. P3 entrega o corpo à criação genérica e D1 aceita papéis previstos no esquema. Sem lista explícita de campos ou regra de atribuição do papel inicial, a conta criada pode ganhar autorização de administrador ou contabilidade.<br>Base: server.ts e models/user.ts. O middleware do desafio registra role admin e prossegue. O teste upstream user.test.ts documenta o comportamento esperado. |

Fonte: elaboração própria.

Quadro 21: Registro de ameaças do FX2, tratamento

| ID / DREAD / risco | Controle existente | Mitigação, camada, referência e aceite |
|---|---|---|
| T-FX2-01<br>9, 9, 9, 8, 9<br>8,8 / Alto<br>Mitigar | Há comparação HMAC e limitador de 100 requisições em cinco minutos. Cinco solicitações chegaram ao mecanismo de reset. | Substituir a pergunta por recuperação com token aleatório de uso único, vida curta e vínculo ao titular por canal verificado, preservando MFA quando ativo. Notificar a troca e encerrar sessões antigas segundo política.<br>Preventivo e corretivo / aplicação. ASVS 5.0.0: 6.4.2, 6.4.3, 7.4.3; guia RESET; LGPD, art. 46.<br>Aceite: Token expirado, já usado ou de outra conta deve falhar. A resposta de recuperação não deve identificar se o e-mail está cadastrado. |
| T-FX2-02<br>8, 6, 7, 5, 7<br>6,6 / Médio<br>Mitigar | UserId é único em D1. A M1 obteve HTTP 400 ao tentar registrar segunda resposta para a mesma conta. | Durante a migração, acoplar criação da conta e associação em transação única com o ID gerado no servidor. Remover a gravação pública isolada quando o novo reset entrar em serviço.<br>Preventivo / aplicação e dados. ASVS 5.0.0: 2.3.1, 2.3.3, 8.2.2; guia AUTHZ; LGPD, art. 46.<br>Aceite: Um cliente não deve conseguir associar resposta a ID indicado por ele. A criação incompleta deve ser revertida sem deixar conta apta a recuperação indevida. |
| T-FX2-03<br>7, 7, 7, 6, 6<br>6,6 / Médio<br>Mitigar | Há log HTTP diário. A prova da recuperação depende do conhecimento da resposta. | Correlacionar abertura, consumo e falhas de recuperação a ID opaco, horário, origem e resultado. Proteger a trilha contra alteração e notificar o canal já cadastrado.<br>Detectivo e corretivo / aplicação e processo. ASVS 5.0.0: 16.2.1, 16.2.5, 16.4.2; guia LOG; LGPD, art. 46.<br>Aceite: Uma operação de teste deve gerar eventos correlacionáveis e uma notificação, sem persistir resposta, nova senha ou token recuperável no log. |
| T-FX2-04<br>5, 9, 9, 7, 8<br>7,6 / Alto<br>Mitigar | A rota não devolve a resposta de segurança. A pergunta associada é visível sem autenticação. | Retirar a consulta pública da pergunta. Receber solicitação de recuperação no corpo, responder com status, conteúdo e tempo comparáveis. Omitir hashes da resposta do reset e excluir e-mails desnecessários dos logs de acesso.<br>Preventivo / aplicação e processo. ASVS 5.0.0: 6.3.8, 14.2.1, 16.2.5; guia RESET; LGPD, art. 46.<br>Aceite: Em amostra local, e-mails cadastrados e não cadastrados devem receber resposta equivalente, com variação temporal compatível. A resposta do reset deve omitir o hash e o log deve omitir o identificador bruto. |
| T-FX2-05<br>6, 7, 8, 7, 7<br>7,0 / Alto<br>Mitigar | A unicidade do e-mail impede duplicata da mesma conta. O limitador de reset não cobre o cadastro. | Limitar cadastros por origem e período com controle contra abuso distribuído, verificar endereço de cadastro e remover contas incompletas conforme regra de retenção.<br>Preventivo e detectivo / aplicação e dados. ASVS 5.0.0: 2.4.1; guia AUTH; LGPD, art. 46.<br>Aceite: Uma sequência de cadastros sintéticos acima da política deve ser contida, com criação e reset legítimos preservados. |
| T-FX2-06<br>10, 8, 9, 9, 9<br>9,0 / Alto<br>Mitigar | O modelo aplica customer como padrão e valida o conjunto de papéis aceitos. Esses controles não restringem o papel recebido a customer. | Usar um DTO de cadastro com campos permitidos e gravar customer a partir de regra interna. Alterar papel somente em operação administrativa distinta, autorizada e auditada.<br>Preventivo / aplicação. ASVS 5.0.0: 8.2.1, 8.2.3, 8.3.1; guia MASS; LGPD, art. 46.<br>Aceite: Pedidos de cadastro com role admin, accounting ou deluxe devem ser rejeitados ou gravados exclusivamente como customer. O perfil emitido deve refletir o papel persistido. |

Fonte: elaboração própria.

Nas notas DREAD, a ordem é dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta. As justificativas abaixo seguem essa ordem.

Quadro 22: Justificativas das notas do FX2

| ID | Justificativa de cada dimensão |
|---|---|
| T-FX2-01 | Dano (9): A senha alterada concede acesso aos dados do titular e pode impedir seu login. Reprodutibilidade (9): O T1 repetiu a tentativa até o quinto palpite e confirmou o acesso. Explorabilidade (9): A rota pública exige e-mail e resposta adivinhável, sem sessão inicial. Usuários (8): O efeito direto é por conta, mas o mecanismo é comum a todas. Descoberta (9): O formulário revela a pergunta associada e facilita a seleção dos palpites. |
| T-FX2-02 | Dano (8): A associação indevida pode preparar a tomada da conta ainda sem resposta. Reprodutibilidade (6): É necessária uma conta alvo sem registro e o caso não foi reproduzido. Explorabilidade (7): A chamada é simples, mas exige conhecer um ID elegível. Usuários (5): A janela restringe o ataque a contas com configuração incompleta. Descoberta (7): O campo UserId é exposto pelo contrato e pela implementação da interface. |
| T-FX2-03 | Dano (7): Uma disputa de conta pode exigir investigação e reversão sem trilha suficiente. Reprodutibilidade (7): O registro genérico é o mesmo mecanismo para todos os resets. Explorabilidade (7): Uma redefinição anônima fornece pouco material para atribuição individual. Usuários (6): Os atingidos são principalmente titulares que sofreram reset indevido. Descoberta (6): A lacuna aparece ao comparar a rota com o conteúdo do log. |
| T-FX2-04 | Dano (5): O retorno revela associação e tema da pergunta, sem entregar a resposta secreta. Reprodutibilidade (9): O retorno da pergunta foi capturado na M1. Explorabilidade (9): A consulta é anônima e requer apenas um e-mail candidato. Usuários (7): A operação se repete para contas com pergunta associada. Descoberta (8): O formulário usa o endpoint e o contraste de saída consta do código. |
| T-FX2-05 | Dano (6): Acúmulo de registros e competição por escrita degradam a mesma base usada pelas contas. Reprodutibilidade (7): Cadastros com identificadores distintos são possíveis, mas a saturação não foi medida. Explorabilidade (8): A rota pública aceita requisições com dados de cadastro. Usuários (7): A degradação do SQLite pode afetar operações de outros usuários. Descoberta (7): O custo das operações é identificável no código e no formulário. |
| T-FX2-06 | Dano (10): O papel privilegiado pode alcançar dados e operações coletivas. Reprodutibilidade (8): Há caminho e teste upstream, sem reprodução no laboratório da equipe. Explorabilidade (9): A operação de registro é pública e o vetor é um campo do corpo. Usuários (9): O papel pode afetar contas e compras de diversos titulares. Descoberta (9): O campo role é reconhecível pelo esquema e pelo código do desafio. |

Fonte: elaboração própria.

### Conclusão e risco residual

O papel inicial precisa ser atribuído no servidor. A recuperação deve abandonar perguntas previsíveis e adotar prova de posse de canal com uso único e prazo curto. Essas correções tratam causas diferentes e precisam de verificação independente. Após a substituição, o risco residual concentra-se no comprometimento do canal de recuperação e na automação de solicitações. Respostas uniformes, cotas por conta e origem, trilha protegida e alerta ao titular reduzem exposição e tempo de reação.

## 6.3 FX3: Cesta, checkout e registro do pedido

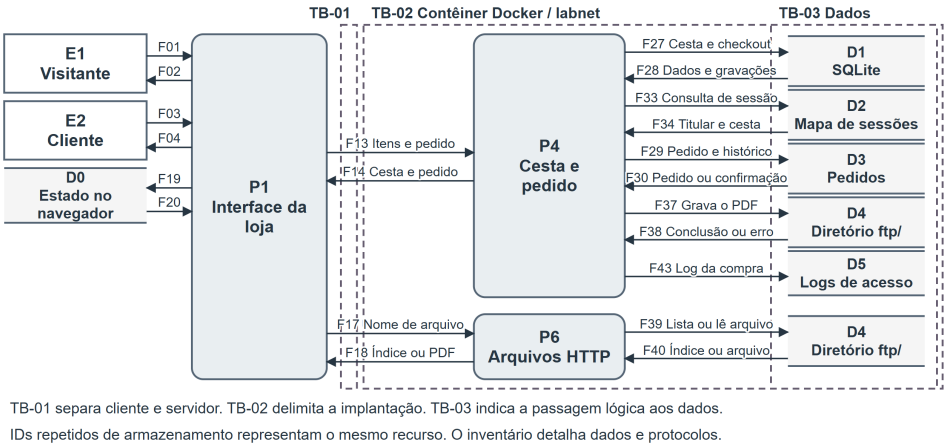
O comprador consulta a cesta, inclui ou ajusta itens, escolhe endereço e meio de pagamento e confirma a compra. O servidor calcula o valor, registra o pedido na coleção em memória e grava um PDF. O histórico e o download permitem consultar o resultado.

Quadro 23: Ficha e dados do FX3

| Campo | Descrição |
|---|---|
| Responsável / revisor | Gustavo Gonçalves Trindade / João Victor Rodrigues Santos |
| Ator e gatilho | Comprador E2 com sessão ao abrir a cesta ou confirmar o pedido. A leitura pública de arquivos em P6 inclui E1 como agente no recorte. |
| Pré-condições | Token da conta, cesta e itens, endereço e opção de entrega quando aplicáveis, cartão sintético ou carteira de demonstração. |
| Resultado | Pedido associado ao comprador e a referências válidas, cesta finalizada e comprovante acessível apenas ao titular na solução pretendida. |
| Itens, quantidade e preço | Público no catálogo e dado pessoal quando vinculado ao pedido; F13, F14, D1, D3 e PDF em D4; propriedade crítica: Integridade. |
| Endereço, nome e telefone | Dado pessoal quando identificável; F13, F14 e D1. Referência de endereço em D3; propriedade crítica: Confidencialidade. |
| Cartão sintético, validade e titular | Dado de pagamento quando real e identificável; F13, D1 e campos mascarados em F14 nas consultas específicas; propriedade crítica: Confidencialidade. |
| JWT, IDs de cesta, entrega, cartão e pedido | Credencial e identificadores vinculáveis; D0, D2, F13, D1, D3 e D4; propriedade crítica: Integridade. |
| E-mail associado ao pedido | Dado pessoal quando identificável; PDF em D4 e forma parcialmente mascarada em D3; propriedade crítica: Confidencialidade. |
| Controle: P4, F13 e D2 | Autenticação na cesta e atribuição de UserId. Base: server.ts e lib/insecurity.ts. A M1 registrou recusa sem token em V3. |
| Controle: P4 e D1 | Filtro de titularidade em consultas específicas de endereço e cartão. Base: routes/address.ts e routes/payment.ts. A listagem de cartão mascara o número. |
| Controle: P4 e D1 | Cálculo de preço e verificação de estoque. Base: routes/order.ts e routes/basketItems.ts. A checagem de estoque foi localizada nas rotas de itens. |
| Controle: P6 e D4 | Restrição de formato no download. Base: routes/fileServer.ts. A regra de formato não valida a titularidade do documento. |

Fonte: elaboração própria.

Figura 5: Recorte do DFD do FX3




TB-01 separa cliente e servidor. TB-02 delimita a implantação. TB-03 indica a passagem lógica aos dados.

IDs repetidos de armazenamento representam o mesmo recurso. O inventário detalha dados e protocolos.

Fonte: elaboração própria.

Quadro 24: Requisições e base de observação do FX3

| Método e rota | Base e observação |
|---|---|
| GET /rest/basket/:id | M1 V3 e V4. HTTP 200 com token de outra conta no ensaio de leitura e erro verboso com header malformado. |
| POST /api/BasketItems e PUT /api/BasketItems/:id | Código v20.2.0. server.ts e routes/basketItems.ts. Adição, ajuste e consulta de estoque. |
| GET e POST /api/Addresss, GET e POST /api/Cards | Código v20.2.0. Rotas de endereço e cartão. A grafia Addresss segue a API. |
| GET /api/Deliverys e POST /rest/basket/:id/checkout | Código e teste upstream. server.ts e routes/order.ts. Há teste upstream de retorno de orderId em basket.test.ts. |
| GET /rest/order-history | Código e teste upstream. Consulta vinculada ao e-mail transformado na coleção de pedidos. Teste em order-history.test.ts. |
| GET /ftp/ e GET /ftp/order_{id}.pdf | M1 V5 para listagem e documento de exemplo. Código para PDF de pedido. order-completion.component.ts, routes/order.ts e fileServer.ts. captura histórica V5 no repositório de evidências. |

Fonte: elaboração própria.

Quadro 25: Transferências de dados do FX3

| F | Origem > destino | Dados | Protocolo / fronteira |
|---|---|---|---|
| F01 | E1 > P1 | Credenciais, cadastro, recuperação, navegação e arquivos públicos | Interface web / formulário; sem travessia |
| F02 | P1 > E1 | Formulários, identidade inicial e respostas públicas | Interface web / renderização; sem travessia |
| F03 | E2 > P1 | Ações autenticadas de sessão, cesta e compra | Interface web / formulário; sem travessia |
| F04 | P1 > E2 | Perfil, itens, estado de compra e comprovante | Interface web / renderização; sem travessia |
| F13 | P1 > P4 | JWT, itens, endereço, cartão de teste e IDs do checkout | HTTP / JSON; TB-01, TB-02 |
| F14 | P4 > P1 | Cesta, meios de pagamento, resultado e confirmação de pedido | HTTP / JSON; TB-01, TB-02 |
| F17 | P1 > P6 | Caminho de listagem ou nome do arquivo | HTTP / caminho; TB-01, TB-02 |
| F18 | P6 > P1 | HTML de listagem ou bytes do documento | HTTP / HTML, PDF ou Markdown; TB-01, TB-02 |
| F19 | P1 > D0 | JWT, cookie e ID da cesta | Web Storage / cookie; sem travessia |
| F20 | D0 > P1 | JWT e ID da cesta para requisições | Web Storage / cookie; sem travessia |
| F27 | P4 > D1 | Cesta, estoque, endereços, cartões, carteira e entrega | Sequelize / SQL local; TB-03 |
| F28 | D1 > P4 | Linhas consultadas e confirmação de gravações | Sequelize / SQL local; TB-03 |
| F29 | P4 > D3 | Registro do pedido ou consulta do histórico | MarsDB / documento em memória; TB-03 |
| F30 | D3 > P4 | Documento de pedido ou resultado da gravação | MarsDB / documento em memória; TB-03 |
| F33 | P4 > D2 | Consulta do JWT para obter titular e cesta | Acesso em memória; TB-03 |
| F34 | D2 > P4 | Perfil associado e ID de cesta | Acesso em memória; TB-03 |
| F37 | P4 > D4 | Gravação do comprovante e identificação do pedido | Sistema de arquivos / PDF; TB-03 |
| F38 | D4 > P4 | Fim da escrita ou erro do arquivo | Sistema de arquivos / PDF; TB-03 |
| F39 | P6 > D4 | Leitura de diretório ou arquivo por nome | Sistema de arquivos / leitura; TB-03 |
| F40 | D4 > P6 | Metadados de arquivos ou documento | Sistema de arquivos / leitura; TB-03 |
| F43 | P4 > D5 | Método, URL, horário, origem e status de cesta e checkout | Escrita local / log HTTP; TB-03 |

Fonte: elaboração própria.

Quadro 26: Matriz STRIDE completa do FX3

| Elemento | S | T | R | I | D | E |
|---|---|---|---|---|---|---|
| D0 | | N/A 11 | | N/A 11 | N/A 10 | |
| D1 | | 02 | | N/A 7 | N/A 6 | |
| D2 | | N/A 7 | | N/A 7 | N/A 6 | |
| D3 | | 02 | | N/A 7 | N/A 6 | |
| D4 | | N/A 7 | | 07 | 05 | |
| D5 | | N/A 9 | 03 | N/A 9 | N/A 9 | |
| E1 | N/A 1 | | N/A 1 | | | |
| E2 | 01 | | 03 | | | |
| P1 | 01 | N/A 13 | N/A 8 | 04, 07 | N/A 10 | N/A 8 |
| P4 | 01 | 02 | 03 | 04, 07 | 05 | 06 |
| P6 | N/A 8 | N/A 7 | N/A 8 | 07 | N/A 10 | N/A 8 |
| F01 | | N/A 13 | | N/A 13 | N/A 6 | |
| F02 | | N/A 13 | | N/A 13 | N/A 6 | |
| F03 | | N/A 13 | | N/A 13 | N/A 6 | |
| F04 | | N/A 13 | | N/A 13 | N/A 6 | |
| F13 | | 02 | | N/A 4 | 05 | |
| F14 | | N/A 3 | | 04 | N/A 6 | |
| F17 | | N/A 2 | | N/A 4 | N/A 12 | |
| F18 | | N/A 3 | | 07 | N/A 6 | |
| F19 | | N/A 11 | | N/A 11 | N/A 6 | |
| F20 | | N/A 11 | | N/A 11 | N/A 6 | |
| F27 | | 02 | | N/A 4 | N/A 6 | |
| F28 | | N/A 3 | | N/A 4 | N/A 6 | |
| F29 | | 02 | | N/A 4 | N/A 6 | |
| F30 | | N/A 3 | | N/A 4 | N/A 6 | |
| F33 | | N/A 3 | | N/A 4 | N/A 6 | |
| F34 | | N/A 3 | | N/A 4 | N/A 6 | |
| F37 | | N/A 3 | | 07 | 05 | |
| F38 | | N/A 3 | | N/A 4 | N/A 6 | |
| F39 | | N/A 3 | | 07 | N/A 6 | |
| F40 | | N/A 3 | | 07 | N/A 6 | |
| F43 | | N/A 9 | | N/A 9 | N/A 6 | |

Fonte: elaboração própria.

Na matriz, 01 significa T-FX3-01, e assim sucessivamente. Célula vazia: categoria inaplicável ao tipo. Os códigos N/A remetem às justificativas após os quatro fluxos.

## Questionário do fluxo

Compreensão. Q1: FX3 converte a compra em pedido/entrega; a consistência entre cesta, titular, pagamento e comprovante protege a integridade da operação e seus dados. Q2: E2 compra após FX1; E1 não deve operar cestas, mas acessa diretório público em P6 e pode provocar erro com Authorization malformado (V4). Q3: P1/F03 chama P4 por HTTP/JSON (F13/F14); seguem SQLite/D1 (F27/F28), memória/D2 (F33/F34), MarsDB/D3 (F29/F30), PDF/D4 (F37/F38) e log/D5 (F43). P6 serve D4 por F39/F40/F18. Q4: Compra/arquivos cruzam TB-01/TB-02; TB-03 separa lógica e armazenamentos. Gravações em D1/D3/D4 exigem consistência entre tecnologias distintas e validação dos objetos recebidos. Q5: Token é credencial; IDs/entrega vinculáveis são pessoais. D1 guarda conta/cesta/cartão sintético; D3, pedido; D4, PDF. Dados financeiros não são automaticamente sensíveis pelo art. 5º, II. Q6: Rotas e JSON recebem IDs, ProductId, BasketId, quantity e orderDetails; Authorization e nome do PDF completam entradas de interface, API e arquivos. Q7: V3 recusou acesso sem token. Código filtra endereço/cartão por UserId, mascara cartão e usa preços armazenados; V3 confirmou ausência de titularidade na cesta.

Falsificação de identidade. S1: E2 apresenta token em F13; P4 usa middleware e mapa de sessões. P6 entrega arquivos elegíveis sem exigir a mesma prova. S2: JWT emitido em FX1 fica em D0/F20; logout limpa a SPA. Amostras históricas não têm exp; validade efetiva depende do verificador da rota. S3: T-FX3-01 considera posse de credencial alheia. V3 usou credencial própria com ID de terceiro, sem falsificar identidade, confirmando falha de titularidade.

Adulteração. T1: IDs/quantidades podem mudar em F13; P4 atualiza D1/D3 e grava D4. Falhas entre destinos podem deixar pedido e cesta inconsistentes. T2: Servidor controla estoque/preço com alcance variável por rota; checkout busca cesta pelo ID recebido e referências do corpo, fundamentando T-FX3-02. T3: HTTP local não fornece integridade criptográfica; JWT não assina campos do checkout. Transações e validação de titularidade precisam abranger os objetos usados.

Repúdio. R1: F43 registra rota, horário, origem, método e status; D3 guarda orderId/estado. Não se identificou trilha única ligada ao ator validado. R2: D5 permanece no mesmo ambiente, com rotação; D3 permite alterações durante entrega e não constitui trilha imutável de eventos do pedido. R3: Em T-FX3-03, alguém pode negar checkout se os registros não correlacionarem identidade, pedido e resultado na mesma cadeia de eventos.

Divulgação de informação. I1: V3 expôs itens/UserId de outra cesta; V4, versão declarada do framework. Exposição de PDF por F18 permanece hipótese apoiada em diretório/código. I2: Cartão mascarado na resposta permanece completo em D1; D3 mascara parcialmente e-mail, presente no PDF. A minimização precisa abranger cada representação. I3: HTTP/loopback não fornece TLS; cifragem de SQLite/PDFs não foi demonstrada documentalmente. Restrições de formato do arquivo não asseguram confidencialidade dos dados.

Disponibilidade. D1: SQLite, mapa, memória de pedidos, CPU, descritores e disco sustentam o fluxo; acúmulo de PDFs em D4 poderia prejudicar novas compras. D2: Rotas de itens verificam estoque, e parser limita corpo; não foi identificada quota específica de checkout/geração de PDF nos trechos examinados. D3: Compra simula pagamento com componentes locais, sem adquirente externo demonstrado; arquivo e coleção local são dependências cuja falha pode afetar o fluxo.

Elevação de privilégio. E1: P4 autentica cesta e filtra algumas consultas de cartão/endereço por titular; cesta de V3 e busca inicial do checkout não aplicam predicado equivalente. E2: V3 confirmou leitura horizontal de cesta em T-FX3-06; alteração de pedido/cesta por T-FX3-02 permanece hipótese, dependente de teste funcional próprio. E3: Node.js usa a identidade prevista na imagem e acessa D1-D4; separação lógica no DFD não demonstra menor privilégio de cada módulo.

Fechamento. V1: T-FX3-06 (8,4) confirma leitura de recurso alheio. T-FX3-02 (7,8) considera escrita potencialmente mais danosa, com menor base empírica para priorização. V2: M1: V3/T-FX3-06, V4/T-FX3-04; V5 confirmou listagem/download de exemplo. M2 reproduziu cesta alheia (200), recusando acesso sem JWT (401). T-FX3-07 permanece hipótese. V3: A revisão documental foi concluída. Checkout completo, concorrência, comprovante de terceiro e titularidade nas demais leituras/escritas não foram testados.

Quadro 27: Registro de ameaças do FX3, identificação

| ID / elementos | Categoria / propriedade / classificação | Cenário e evidência |
|---|---|---|
| T-FX3-01<br>P4, P1, E2 | S / Autenticidade<br>CWE-294, CWE-613 / A07<br>Plausível | Um agente que obtenha o token de um comprador pode se apresentar como E2 em P4 por F13. O token portador armazenado em D0 é reutilizável e a limpeza local no logout não demonstra revogação no servidor. O agente pode consultar dados ou operar como o comprador.<br>Base: login.component.ts, request.interceptor.ts, navbar.component.ts e lib/insecurity.ts. JWT amostral sem exp na M1. |
| T-FX3-02<br>P4, F13, F27, F29, D1, D3 | T / Integridade<br>CWE-639, CWE-862 / A01<br>Plausível | Um comprador E2 pode alterar o identificador da cesta em F13 ou informar referências de endereço e pagamento fora da sua conta. P4 busca a cesta pelo ID recebido e grava referências no pedido. Se o checkout prosseguir, pode registrar compra inconsistente e remover itens da cesta de terceiro.<br>Base: routes/order.ts. O método procura a cesta por id e lê paymentId e addressId enviados no corpo. |
| T-FX3-03<br>D5, P4, E2 | R / Não repúdio<br>CWE-778 / A09<br>Plausível | Um comprador E2 pode contestar a autoria de um checkout em P4 quando o registro de D5 não vincula a chamada em F43 ao identificador do pedido, à identidade validada e ao resultado do pagamento simulado. Isso dificulta reconstruir a transação e responder à disputa.<br>Base: server.ts e routes/order.ts. Registro HTTP e coleção de pedido têm finalidades distintas. |
| T-FX3-04<br>F14, P4, P1 | I / Confidencialidade<br>CWE-209 / A05<br>Confirmada no T1 (V4) | Um visitante E1 com acesso local pode induzir erro ao enviar Authorization malformado para F13. O tratamento devolve em F14 detalhes do framework em HTML, que o agente pode usar para reconhecimento do ambiente.<br>Base: V4. Authorization malformado na rota de cesta retornou HTML com framework e versão declarada. |
| T-FX3-05<br>P4, D4, F13, F37 | D / Disponibilidade<br>CWE-400 / A04<br>Plausível | Um comprador E2 pode disparar checkouts concorrentes em P4 e criar PDFs em D4. Sem orçamento de geração por conta e política de descarte identificados, o volume pode consumir CPU, descritores e espaço, degradando compras ou outras funções da instância.<br>Base: routes/order.ts. O checkout produz PDF e grava no mesmo sistema de arquivos usado pela loja. |
| T-FX3-06<br>P4 | E / Autorização<br>CWE-639 / A01<br>Confirmada no T1 (V3) | Um comprador E2 pode solicitar em F13 o ID da cesta de outro titular. P4 valida a sessão, mas consulta D1 pelo identificador sem filtrar o dono. O agente ultrapassa a autorização da própria conta e recebe itens e vínculo com outro usuário em F14.<br>Base: V3. Uma conta autenticada consultou a cesta de outra e recebeu HTTP 200 com dados da cesta. |
| T-FX3-07<br>P6, P1, P4, D4, F18, F37, F39, F40 | I / Confidencialidade<br>CWE-548, CWE-862 / A05<br>Plausível | Um visitante com acesso local pode tentar localizar um comprovante em D4 e solicitá-lo a P6. O checkout grava o PDF no diretório servido via HTTP, e a entrega de arquivos não verifica titularidade. Se o arquivo estiver presente, a exposição pode incluir e-mail e detalhes do pedido.<br>Base: V5 confirma o canal público /ftp/. routes/order.ts e routes/fileServer.ts ligam o PDF de pedido ao canal. A M1 não capturou um comprovante de terceiro. |

Fonte: elaboração própria.

Quadro 28: Registro de ameaças do FX3, tratamento

| ID / DREAD / risco | Controle existente | Mitigação, camada, referência e aceite |
|---|---|---|
| T-FX3-01<br>8, 7, 6, 7, 7<br>7,0 / Alto<br>Mitigar | Rotas de cesta verificam autenticação e consultam a identidade no mapa de sessões. O logout limpa o estado no navegador. | Aplicar HTTPS fora do laboratório e sessão curta com revogação no servidor. Preferir cookie HttpOnly, Secure e SameSite para sessão no mesmo domínio, com defesa contra CSRF nas ações de escrita.<br>Preventivo e corretivo / aplicação e rede. ASVS 5.0.0: 7.3.2, 7.4.1, 12.2.1; guia SESS; LGPD, art. 46.<br>Aceite: Após encerrar ou expirar uma sessão de teste, a mesma credencial deve falhar nas leituras e escritas de cesta. |
| T-FX3-02<br>9, 8, 7, 8, 7<br>7,8 / Alto<br>Mitigar | O servidor associa o UserId à sessão e calcula preços e entrega com dados internos. O fluxo de leitura de cartão e endereço tem filtros próprios. | Consultar cesta e referências pela chave do objeto mais o titular da sessão. Recalcular valores no servidor, validar estoque e usar operação idempotente com compensação explícita para efeitos distribuídos entre SQLite, MarsDB e PDF.<br>Preventivo / aplicação e dados. ASVS 5.0.0: 2.3.1, 2.3.3, 8.2.2; guia AUTHZ; LGPD, art. 46.<br>Aceite: Com duas contas sintéticas, negar o checkout com cesta, endereço ou cartão da outra conta. Reenviar o pedido autorizado deve produzir no máximo um pedido e um débito. |
| T-FX3-03<br>7, 7, 6, 6, 6<br>6,4 / Médio<br>Mitigar | Há confirmação com orderId e registro de horário, rota e status HTTP. O histórico mascara vogais do e-mail. | Emitir evento de pedido com ID interno do ator, orderId, cesta, chave de idempotência, horário e resultado. Enviar a trilha protegida sem número de cartão nem endereço completo.<br>Detectivo e corretivo / aplicação e processo. ASVS 5.0.0: 16.2.1, 16.2.5, 16.4.2; guia LOG; LGPD, art. 46.<br>Aceite: Dois pedidos de teste devem ser localizados por orderId na trilha. Tentativas de alterar o evento pela conta do serviço devem falhar. |
| T-FX3-04<br>4, 9, 9, 6, 8<br>7,2 / Alto<br>Mitigar | Middleware rejeita credencial malformada. O handler de erro devolve título detalhado. | Responder falhas de autenticação com erro genérico em JSON e ID de correlação. Conservar detalhes necessários em registro de acesso restrito e validar cabeçalhos da configuração implantada.<br>Preventivo e detectivo / aplicação. ASVS 5.0.0: 13.4.2, 13.4.6, 16.5.1; guia ERR; LGPD, art. 46.<br>Aceite: Um cabeçalho malformado deve devolver falha controlada sem versão, stack trace ou caminho interno. |
| T-FX3-05<br>7, 6, 7, 8, 7<br>7,0 / Alto<br>Mitigar | A rota requer sessão e cesta existente. O fluxo verifica estoque na inclusão de itens, com geração local de PDF no checkout. | Impor limite de concorrência, tempo e tamanho de pedido e PDF por conta. Separar a área de comprovantes, aplicar quota e política de retenção e alertar sobre falhas de escrita.<br>Preventivo e detectivo / aplicação e operação. ASVS 5.0.0: 2.4.1, 13.1.3, 14.2.7; guia DOS; LGPD, art. 46.<br>Aceite: Um ensaio local controlado deve respeitar as cotas e manter acessíveis as consultas legítimas quando o limite de geração for atingido. |
| T-FX3-06<br>8, 10, 8, 8, 8<br>8,4 / Alto<br>Mitigar | O middleware exige JWT e injeta UserId no corpo. A consulta de cesta usa o id da URL como filtro de objeto. | Derivar UserId do contexto validado e incluí-lo no filtro da consulta com a chave de cesta. Aplicar a mesma política de titularidade às operações de itens e checkout.<br>Preventivo / aplicação e dados. ASVS 5.0.0: 8.2.2, 8.3.1; guia IDOR; LGPD, art. 46.<br>Aceite: Com JWT de A, uma leitura da cesta de B deve retornar 403 ou 404. A leitura da cesta de A deve continuar retornando apenas os dados autorizados. |
| T-FX3-07<br>7, 8, 8, 7, 8<br>7,6 / Alto<br>Mitigar | Há restrições de formato e caminho no manipulador. O nome incorpora uma parte aleatória. V5 comprova a listagem de documentos de exemplo. | Guardar PDFs em área privada, desativar a listagem e entregar comprovantes por rota que verifique titularidade no servidor. Revisar e remover artefatos públicos já gerados.<br>Preventivo e corretivo / aplicação e dados. ASVS 5.0.0: 8.2.2, 13.4.3, 14.2.7; guia AUTHZ; LGPD, art. 46.<br>Aceite: Acesso sem sessão ou com conta alheia deve falhar tanto pela rota autenticada quanto pelo endereço público antigo. |

Fonte: elaboração própria.

Nas notas DREAD, a ordem é dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta. As justificativas abaixo seguem essa ordem.

Quadro 29: Justificativas das notas do FX3

| ID | Justificativa de cada dimensão |
|---|---|
| T-FX3-01 | Dano (8): A sessão permite agir sobre a cesta e dados vinculados a uma conta. Reprodutibilidade (7): O replay depende de capturar um token ainda aceito. Explorabilidade (6): Primeiro é necessário acesso à credencial de sessão. Usuários (7): Cada token reutilizado afeta a conta à qual está vinculado. Descoberta (7): O armazenamento e a ausência de exp nas amostras são verificáveis. |
| T-FX3-02 | Dano (9): A escrita pode alterar cestas, comprometer a integridade de pedidos e gerar disputa. Reprodutibilidade (8): O código mostra o caminho, mas a alteração da cesta alheia não foi executada na M1. Explorabilidade (7): Requer conta válida, objeto elegível e montagem do pedido. Usuários (8): A mesma condição pode afetar diferentes titulares se os IDs forem conhecidos. Descoberta (7): A rota usa um identificador visível e o código indica onde é consumido. |
| T-FX3-03 | Dano (7): A operação contestada pode exigir reversão e investigação manual. Reprodutibilidade (7): As rotas repetem o mesmo formato de log. Explorabilidade (6): É preciso existir um pedido e uma disputa de autoria. Usuários (6): O impacto incide nos titulares e pedidos sem correlação. Descoberta (6): A lacuna aparece ao comparar registros de acesso e histórico. |
| T-FX3-04 | Dano (4): A resposta evidencia tecnologia e versão, sem demonstrar acesso a dados de conta. Reprodutibilidade (9): O T1 preservou requisição e corpo HTML da resposta. Explorabilidade (9): Uma chamada com cabeçalho inválido é suficiente. Usuários (6): A informação descreve a instância e beneficia ataques posteriores. Descoberta (8): O erro pode ser induzido diretamente na rota de cesta. |
| T-FX3-05 | Dano (7): Recursos compartilhados tornam o checkout e o servidor suscetíveis a degradação. Reprodutibilidade (6): O limiar de saturação depende da instância e não foi medido. Explorabilidade (7): Uma conta válida permite iniciar checkouts, sob as condições do fluxo. Usuários (8): I/O e CPU são compartilhados com os demais compradores. Descoberta (7): A geração de PDF e o armazenamento aparecem no caminho de compra. |
| T-FX3-06 | Dano (8): A resposta expõe itens e vínculo de usuário de outra conta. Reprodutibilidade (10): O T1 confirmou a leitura com duas contas de teste e evidência HTTP. Explorabilidade (8): Exige uma conta válida e um ID diferente. Usuários (8): Identificadores numéricos permitem repetir o cenário para outros titulares. Descoberta (8): O ID aparece na rota e é verificável pela interface de rede. |
| T-FX3-07 | Dano (7): O PDF pode associar o titular a uma compra e revelar seus itens. Reprodutibilidade (8): O caminho aparece no código, mas o acesso a um recibo de terceiro não foi exercitado no T1. Explorabilidade (8): Se listado ou obtido o nome, basta a requisição HTTP. Usuários (7): O conjunto exposto depende dos comprovantes existentes e da retenção. Descoberta (8): O caminho de download aparece na interface e há listagem do diretório. |

Fonte: elaboração própria.

### Conclusão e risco residual

A leitura confirmada torna prioritária a autorização por objeto. A mesma política precisa ser avaliada em itens, checkout e comprovantes, pois são caminhos distintos para dados do titular. Recalcular preços no servidor protege apenas uma parte da integridade da transação. Mesmo com autorização por objeto, a consistência entre pedido, débito simulado, cesta e arquivo depende de idempotência e tratamento de falhas. O risco residual inclui roubo de sessão e falhas parciais entre armazenamentos. A verificação precisa cobrir repetição e concorrência.

## 6.4 FX4: Administração e contabilidade

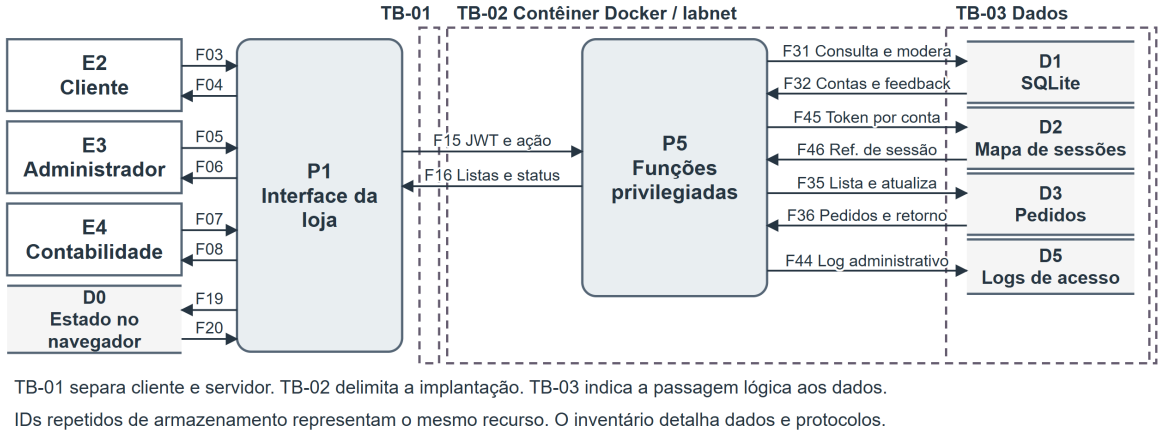
A interface administrativa lista contas e feedbacks e permite moderação. A interface contábil consulta pedidos e envia a alteração de entrega. As duas usam sessão, mas as rotas adotam verificações distintas no servidor. O recorte compara essas diferenças.

Quadro 30: Ficha e dados do FX4

| Campo | Descrição |
|---|---|
| Responsável / revisor | João Victor Rodrigues Santos / Leonardo Pacheco B Dias |
| Ator e gatilho | Administrador E3 ao consultar ou moderar e operador E4 ao consultar pedidos ou registrar entrega. Cliente E2 é o papel usado para avaliar solicitações fora da permissão. |
| Pré-condições | Sessão válida e autorização administrativa ou contábil conforme a ação. Um pedido existente é necessário para conferir mudança efetiva de estado. |
| Resultado | Consultas restritas ao papel e à finalidade. Moderação e transição de entrega com autoria registrada e alteração apenas do recurso autorizado. |
| E-mail, ID, papel e metadados de sessão | Dado pessoal quando identificável, papel interno; F15, F16, D1 e D2; propriedade crítica: Confidencialidade. |
| Feedback, nota e vínculo de autoria | Público na exibição autorizada e dado pessoal se identificável; F16, F31, F32 e D1; propriedade crítica: Integridade. |
| Pedido, referências e status de entrega | Dado pessoal quando vinculável e estado interno; F15, F16, D3, F35 e F36; propriedade crítica: Integridade. |
| Token de administrador ou de contabilidade | Credencial ou segredo; D0 e F15; propriedade crítica: Confidencialidade. |
| Metadados da operação | Interno e dado pessoal quando vinculável; F44 e D5; propriedade crítica: Integridade. |
| Controle: P1 | Guarda de rota Angular. Base: app.guard.ts e configuração de rotas. Controla navegação na interface. |
| Controle: P5 e F15 | Autenticação nas listagens de contas e na exclusão de feedback. Base: server.ts. As rotas listadas usam isAuthorized. |
| Controle: P5 e F15 | Filtro de papel na contabilidade. Base: isAccounting em lib/insecurity.ts. Teste upstream documenta permissões esperadas. |
| Controle: P5 e F16 | Mascaramento ou exclusão de segredos. Base: routes/authenticatedUsers.ts e configuração de User no server.ts. |

Fonte: elaboração própria.

Figura 6: Recorte do DFD do FX4




Fonte: elaboração própria.

Quadro 31: Requisições e base de observação do FX4

| Método e rota | Base e observação |
|---|---|
| GET /rest/user/authentication-details/ e GET /api/Users | Código e teste upstream. user.service.ts usa authentication-details/ para a listagem. GET /api/Users é rota direta alternativa. inspeção do código e dos testes da versão. |
| GET /api/Users/:id, GET /api/Feedbacks e DELETE /api/Feedbacks/:id | Código v20.2.0. Consulta de detalhe, listagem pública utilizada pela SPA e exclusão. A proteção dessas ações difere. |
| GET /rest/order-history/orders e PUT /rest/order-history/:id/delivery-status | Código e teste upstream. routes/orderHistory.ts e teste order-history.test.ts. O projeto prevê accounting autorizado e customer/admin recusados. |

Fonte: elaboração própria.

Quadro 32: Transferências de dados do FX4

| F | Origem > destino | Dados | Protocolo / fronteira |
|---|---|---|---|
| F03 | E2 > P1 | Ações autenticadas de sessão, cesta e compra | Interface web / formulário; sem travessia |
| F04 | P1 > E2 | Perfil, itens, estado de compra e comprovante | Interface web / renderização; sem travessia |
| F05 | E3 > P1 | Consulta de usuários e moderação de feedback | Interface web / formulário; sem travessia |
| F06 | P1 > E3 | Listas e resultado da moderação | Interface web / renderização; sem travessia |
| F07 | E4 > P1 | Consulta de pedidos e comando de entrega | Interface web / formulário; sem travessia |
| F08 | P1 > E4 | Pedidos e estado de entrega | Interface web / renderização; sem travessia |
| F15 | P1 > P5 | JWT, consultas e comandos de moderação ou entrega | HTTP / JSON; TB-01, TB-02 |
| F16 | P5 > P1 | Dados de contas, feedbacks e pedidos, resultado das operações | HTTP / JSON; TB-01, TB-02 |
| F19 | P1 > D0 | JWT, cookie e ID da cesta | Web Storage / cookie; sem travessia |
| F20 | D0 > P1 | JWT e ID da cesta para requisições | Web Storage / cookie; sem travessia |
| F31 | P5 > D1 | Consulta de contas e feedbacks ou exclusão de feedback | Sequelize / SQL local; TB-03 |
| F32 | D1 > P5 | Linhas consultadas ou resultado da exclusão | Sequelize / SQL local; TB-03 |
| F35 | P5 > D3 | Consulta de pedidos ou alteração da entrega por ID | MarsDB / documento em memória; TB-03 |
| F36 | D3 > P5 | Pedidos e resultado de atualização | MarsDB / documento em memória; TB-03 |
| F44 | P5 > D5 | Método, URL, horário, origem e status de operações privilegiadas | Escrita local / log HTTP; TB-03 |
| F45 | P5 > D2 | Consulta do token associado a cada conta listada | Acesso em memória; TB-03 |
| F46 | D2 > P5 | Referência à sessão e horário declarado de emissão | Acesso em memória; TB-03 |

Fonte: elaboração própria.

Quadro 33: Matriz STRIDE completa do FX4

| Elemento | S | T | R | I | D | E |
|---|---|---|---|---|---|---|
| D0 | | N/A 11 | | N/A 11 | N/A 10 | |
| D1 | | N/A 7 | | N/A 7 | N/A 6 | |
| D2 | | N/A 7 | | N/A 7 | N/A 6 | |
| D3 | | 02 | | N/A 7 | 05 | |
| D5 | | N/A 9 | 03 | N/A 9 | N/A 9 | |
| E2 | N/A 1 | | N/A 1 | | | |
| E3 | N/A 1 | | 03 | | | |
| E4 | 01 | | 03 | | | |
| P1 | 01 | N/A 13 | N/A 8 | 04 | N/A 10 | N/A 8 |
| P5 | 01 | 02 | 03 | 04 | 05 | 06 |
| F03 | | N/A 13 | | N/A 13 | N/A 6 | |
| F04 | | N/A 13 | | N/A 13 | N/A 6 | |
| F05 | | N/A 13 | | N/A 13 | N/A 6 | |
| F06 | | N/A 13 | | N/A 13 | N/A 6 | |
| F07 | | N/A 13 | | N/A 13 | N/A 6 | |
| F08 | | N/A 13 | | N/A 13 | N/A 6 | |
| F15 | | 02 | | N/A 4 | 05 | |
| F16 | | N/A 3 | | 04 | 05 | |
| F19 | | N/A 11 | | N/A 11 | N/A 6 | |
| F20 | | N/A 11 | | N/A 11 | N/A 6 | |
| F31 | | N/A 3 | | N/A 4 | N/A 6 | |
| F32 | | N/A 3 | | 04 | N/A 6 | |
| F35 | | 02 | | N/A 4 | 05 | |
| F36 | | N/A 3 | | N/A 4 | 05 | |
| F44 | | N/A 9 | | N/A 9 | N/A 6 | |
| F45 | | N/A 3 | | N/A 4 | N/A 6 | |
| F46 | | N/A 3 | | 04 | N/A 6 | |

Fonte: elaboração própria.

Na matriz, 01 significa T-FX4-01, e assim sucessivamente. Célula vazia: categoria inaplicável ao tipo. Os códigos N/A remetem às justificativas após os quatro fluxos.

## Questionário do fluxo

Compreensão. Q1: FX4 reúne consultas e ações privilegiadas; falhas em P5 podem permitir que clientes consultem contas ou removam feedbacks de outros titulares. Q2: E3 administra; E4 consulta pedidos/altera entrega. Admin não implica accounting no código; E2 representa chamadas diretas tentadas fora da permissão. Q3: F05/F07 acionam P1; F15/F16 levam HTTP/JSON a P5, que consulta SQLite/D1 (F31/F32), memória/D2 (F45/F46) e MarsDB/D3 (F35/F36), registrando metadados em D5/F44. Q4: F15/F16 cruzam TB-01/TB-02 e exigem autorização na API; F31/F32/F35/F36/F44/F45/F46 cruzam TB-03, dando à requisição alcance sobre registros de vários titulares. Q5: F16 reúne identificação/feedback/pedidos; JWT é credencial. D1 guarda conta/feedback; D2, sessão; D3, pedido/entrega. Não se identificaram dados sensíveis no esquema. Q6: Superfície administrativa: fragmentos Angular, rotas HTTP independentes, Authorization, IDs de feedback/pedido e deliveryStatus; ocultar navegação na SPA não restringe a API. Q7: SPA verifica papel; servidor usa isAccounting na contabilidade. Listagem de usuários/exclusão de feedback verificam JWT sem papel equivalente; listagens filtram/mascaram campos.

Falsificação de identidade. S1: P5 verifica tokens; contabilidade exige assinatura e claim de papel. D1/D2/D3 são acessados com permissões do processo, sem identidade própria por módulo. S2: JWT vem de FX1 e segue por F15; isAccounting verifica assinatura/papel. Não se identificou consulta ao papel atual nem invalidação nesse percurso. S3: T-FX4-01 considera JWT de E4 após perda de acesso; T-FX1-06 afeta o fluxo se a chave permitir falsificar tokens de papéis reservados.

Adulteração. T1: Cliente pode alterar deliveryStatus/IDs antes de F15; P5 modifica pedidos em D3 e, na exclusão de feedback, registros em D1. T2: Contabilidade exige accounting, porém inverte deliveryStatus recebido sem comparar o persistido; exclusão de feedback exige autorização de função além do ID. T3: Assinatura confiável protege claims do JWT; comando usa HTTP local sem assinatura própria. Integridade da entrega exige validar transição de estado.

Repúdio. R1: F44 registra requisições HTTP; não foi identificada trilha específica ligando ator validado, exclusão, pedido e estados anterior/posterior da operação privilegiada. R2: D5 é local, com rotação; não foram

identificadas garantias de integridade nem proteção contra alterações por contas com acesso ao arquivo. R3: Em T-FX4-03, administrador/contador poderia negar autoria quando a trilha não correlaciona identidade, alvo, ação e resultado da operação sob investigação.

Divulgação de informação. I1: F16 lista contas; authentication-details mascara password/totpSecret e expõe outros campos. M2 confirmou consulta por customer; GET /api/Users exclui segredos sem exigir admin. I2: Painel precisa de campos restritos para identificar conta/estado; respostas amplas e pedidos completos aumentam exposição sem finalidade demonstrada para cada campo. I3: HTTP local não protege transporte; mascaramento reduz exposição de campos específicos. Não se demonstrou cifragem de D1/D5 em repouso na configuração examinada.

Disponibilidade. D1: Listas amplas consomem memória/CPU de consulta e serialização; a listagem de pedidos usa find()/reverse(), com potencial de pressão no processo compartilhado. D2: Trechos examinados não paginam listagens no servidor; a SPA pode paginar depois de receber tudo. Saturação por volume não foi medida. D3: FX4 depende de API, SQLite, mapa e MarsDB locais; falhas em integrações externas e seus mecanismos de recuperação não foram analisados.

Elevação de privilégio. E1: API contábil verifica papel; AdminGuard restringe navegação, e isAuthorized autentica ações administrativas. Cada operação requer autorização de função e recurso aplicável. E2: A M2 confirmou T-FX4-04: customer obteve authentication-details (200), listando usuários. T-FX4-06 permanece plausível; exclusão de feedback não foi testada. E3: A identidade compartilhada do contêiner não separa deveres de E3/E4; consultar contas, moderar feedbacks e alterar entrega precisam de permissões específicas.

Fechamento. V1: T-FX4-04 (8,6), reproduzida na M2, expõe várias contas por chamada. T-FX4-06 (8,2) considera exclusão indevida de conteúdo, afetando terceiros e integridade. V2: A M1 não confirmou ameaças de FX4. M2 confirmou T-FX4-04; T-FX4-01/02/03/05/06 permanecem plausíveis. V1/V2/V6 informam dependências do token. V3: A revisão documental foi concluída. Cobertura integral por rota/papel, rebaixamento, concorrência de entrega e disponibilidade com coleções crescentes não foram testados.

Quadro 34: Registro de ameaças do FX4, identificação

| ID / elementos | Categoria / propriedade / classificação | Cenário e evidência |
|---|---|---|
| T-FX4-01<br>P5, E4, P1 | S / Autenticidade<br>CWE-613 / A07<br>Plausível | Um ex-operador de contabilidade pode tentar apresentar em F15 um JWT emitido antes de perder acesso. P5 baseia a identidade contábil na assinatura e no papel transportado pelo token, permitindo que uma sessão antiga ainda represente E4 se o token continuar aceito.<br>Base: lib/insecurity.ts e routes/orderHistory.ts. isAccounting verifica assinatura e papel. A verificação observada no código não consulta estado atual da conta. |
| T-FX4-02<br>P5, D3, F15, F35 | T / Integridade<br>CWE-345, CWE-841 / A04<br>Plausível | Um operador E4 pode enviar em F15 um estado anterior incorreto ou desatualizado. P5 inverte o valor recebido e grava em D3 sem comparar com a versão persistida. Com isso, pode desfazer uma atualização legítima ou produzir uma transição que não corresponde ao estado real.<br>Base: routes/orderHistory.ts, toggleDeliveryStatus. O valor gravado deriva de !req.body.deliveryStatus. |
| T-FX4-03<br>D5, P5, E3, E4 | R / Não repúdio<br>CWE-778 / A09<br>Plausível | Um administrador E3 ou operador E4 pode contestar a exclusão de um feedback ou uma alteração de entrega. F44 e D5 registram o acesso HTTP, porém não preservam de forma associada autor validado, estado anterior e resultado da ação.<br>Base: server.ts, Morgan combined, e handlers de feedback e pedido. Não foi identificada trilha de antes e depois para o escopo. |
| T-FX4-04<br>F16, P1, P5, F32, F46 | I / Confidencialidade<br>CWE-862, CWE-200 / A01<br>Plausível na análise inicial; reproduzida na M2 por HTTP | Um comprador com JWT válido pode chamar diretamente P5 por F15 e tentar obter a lista de usuários em F16. O servidor verifica autenticação sem conferir o papel administrativo, expondo dados de contas, como e-mails e papéis, fora da finalidade da sessão.<br>Base: server.ts, authenticatedUsers.ts e user.service.ts. A listagem da interface chama authentication-details. Essa rota e GET /api/Users usam isAuthorized sem checagem de admin. |
| T-FX4-05<br>P5, F15, F16, D3, F35, F36 | D / Disponibilidade<br>CWE-400 / A04<br>Plausível | Um operador E4 pode repetir a listagem integral de pedidos em P5 e D3. À medida que a coleção cresce, leitura, ordenação inversa e serialização podem ocupar memória e CPU, degradando o atendimento aos demais usuários.<br>Base: routes/orderHistory.ts, allOrders chama find() e reverse() sem paginação. O acesso requer accounting. |
| T-FX4-06<br>P5 | E / Autorização<br>CWE-862, CWE-285 / A01<br>Plausível | Um comprador com JWT válido pode tentar excluir um feedback em P5 enviando o ID pelo fluxo F15. A rota protegida apenas por autenticação pode aceitar uma função reservada e remover de D1 um registro que a conta não tem permissão de moderar.<br>Base: server.ts e administration.component.ts. DELETE /api/Feedbacks/:id passa por isAuthorized e pelo recurso gerado. A M1 não testou essa ação. |

Fonte: elaboração própria.

Quadro 35: Registro de ameaças do FX4, tratamento

| ID / DREAD / risco | Controle existente | Mitigação, camada, referência e aceite |
|---|---|---|
| T-FX4-01<br>8, 7, 6, 7, 7<br>7,0 / Alto<br>Mitigar | Existe verificação de assinatura e papel accounting no servidor para as duas rotas de pedido. | Consultar estado e papel atual nas ações de contabilidade, revogar imediatamente as sessões de conta desativada ou rebaixada e validar as claims temporais.<br>Preventivo e corretivo / aplicação. ASVS 5.0.0: 7.4.2, 8.3.2, 9.2.1; guia SESS; LGPD, art. 46.<br>Aceite: Obter token com papel accounting, remover esse papel em ambiente de teste e confirmar que o mesmo token deixa de ler ou atualizar pedidos. |
| T-FX4-02<br>7, 8, 7, 7, 7<br>7,2 / Alto<br>Mitigar | A rota exige papel accounting. A atualização seleciona o documento pelo _id. | Receber estado de destino e versão esperada, validar transições permitidas e aplicar atualização condicional atômica no documento. Informar conflito quando a versão divergir ou 404 quando o pedido não existir.<br>Preventivo e detectivo / aplicação e dados. ASVS 5.0.0: 2.3.1, 2.3.3; guia BIZ; LGPD, art. 46.<br>Aceite: Duas alterações concorrentes com a mesma versão devem produzir no máximo um sucesso. Versão velha, estado inválido e ID ausente devem ser rejeitados. |
| T-FX4-03<br>7, 7, 7, 7, 6<br>6,8 / Médio<br>Mitigar | Há registro de horário, rota, método e status na camada HTTP. | Gravar auditoria com ator, papel efetivo, recurso, valores pertinentes antes e depois, decisão de autorização e horário. Separar o destino e proteger escrita e retenção.<br>Detectivo e corretivo / aplicação e processo. ASVS 5.0.0: 16.2.1, 16.3.2, 16.4.2, 16.4.3; guia LOG; LGPD, art. 46.<br>Aceite: Excluir um feedback de teste e alterar entrega deve gerar eventos distintos e íntegros. Credenciais e corpo integral de pedidos devem ficar fora da trilha. |
| T-FX4-04<br>8, 9, 8, 9, 9<br>8,6 / Alto<br>Mitigar | authentication-details mascara password e totpSecret. GET /api/Users os exclui. O AdminGuard limita a navegação na SPA. | Exigir permissão explícita de leitura de contas no servidor, limitar campos à finalidade da tela e paginar o resultado. Registrar consultas privilegiadas.<br>Preventivo / aplicação e dados. ASVS 5.0.0: 8.2.1, 8.2.3, 8.3.1, 14.2.6; guia AUTHZ; LGPD, art. 46.<br>Aceite: Token de cliente ou contabilidade sem permissão deve receber 403. A resposta autorizada deve conter apenas os campos permitidos. |
| T-FX4-05<br>7, 6, 6, 8, 7<br>6,8 / Médio<br>Mitigar | A rota exige o papel accounting e usa uma coleção em memória. A consulta não tem paginação no trecho analisado. | Implementar paginação no servidor com tamanho máximo, consulta por filtros e limite por identidade. Medir latência e tamanho da resposta por rota.<br>Preventivo e detectivo / aplicação e dados. ASVS 5.0.0: 2.4.1, 13.1.3; guia DOS; LGPD, art. 46.<br>Aceite: Com massa sintética crescente, o tamanho máximo da página deve ser respeitado e uma consulta legítima simultânea deve continuar atendida. |
| T-FX4-06<br>8, 8, 8, 8, 9<br>8,2 / Alto<br>Mitigar | A guarda da SPA restringe a tela de administração. A rota requer JWT, e o PUT possui bloqueio específico. | Exigir permissão de moderação na rota DELETE, negar por padrão e registrar autor e recurso. Controlar reversão ou retenção de moderação conforme a finalidade do feedback.<br>Preventivo e detectivo / aplicação. ASVS 5.0.0: 8.2.1, 8.3.1, 16.3.2; guia AUTHZ; LGPD, art. 46.<br>Aceite: Em instância de teste, cliente sem permissão recebe 403 e o feedback permanece. Operador autorizado pode moderar e a trilha registra a decisão. |

Fonte: elaboração própria.

Nas notas DREAD, a ordem é dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta. As justificativas abaixo seguem essa ordem.

Quadro 36: Justificativas das notas do FX4

| ID | Justificativa de cada dimensão |
|---|---|
| T-FX4-01 | Dano (8): A sessão contábil expõe pedidos e permite mudar estado de entrega. Reprodutibilidade (7): O efeito exige token emitido e mudança de acesso, sequência não testada. Explorabilidade (6): O agente precisa ter retido um token contábil utilizável. Usuários (7): O papel alcança mais pedidos do que uma sessão comum. Descoberta (7): A implementação da verificação permite identificar as claims usadas. |
| T-FX4-02 | Dano (7): Um pedido pode figurar como entregue ou em trânsito no momento errado. Reprodutibilidade (8): O caminho é determinístico quando o corpo diverge do registro real. Explorabilidade (7): Requer sessão contábil e identificador do pedido. Usuários (7): Cada gravação afeta o pedido escolhido, com repetição possível. Descoberta (7): O corpo e a atribuição podem ser conferidos no código da versão. |
| T-FX4-03 | Dano (7): A falta de atribuição dificulta responsabilização e correção de pedidos e feedbacks. Reprodutibilidade (7): As ações selecionadas passam pelo mesmo registro HTTP. Explorabilidade (7): O agente precisa praticar ou contestar uma ação em investigação. Usuários (7): As duas operações podem atingir recursos de vários titulares. Descoberta (6): A deficiência depende da inspeção do registro e da rota. |
| T-FX4-04 | Dano (8): A lista reúne dados identificáveis de várias contas. Reprodutibilidade (9): A rota e o middleware são conhecidos, com confirmação local ainda pendente. Explorabilidade (8): Uma sessão comum e cliente HTTP bastariam no cenário descrito. Usuários (9): Uma única listagem pode alcançar diversos titulares. Descoberta (9): A interface administrativa revela a rota de listagem em suas chamadas. |
| T-FX4-05 | Dano (7): A pressão sobre o processo compartilhado pode afetar atendimento e back-office. Reprodutibilidade (6): O limiar depende de volume e concorrência, que não foram ensaiados. Explorabilidade (6): É necessária sessão contábil e uma coleção com volume significativo. Usuários (8): O servidor de pedidos também atende outros fluxos da loja. Descoberta (7): É possível identificar listagem integral pelo método da rota. |
| T-FX4-06 | Dano (8): A exclusão pode adulterar a percepção do catálogo e retirar manifestações de terceiros. Reprodutibilidade (8): A hipótese foi localizada em código. O efeito não foi reproduzido na M1. Explorabilidade (8): Uma conta comum e o ID de feedback seriam suficientes no cenário. Usuários (8): O mesmo controle protege a operação para todos os feedbacks. Descoberta (9): O endpoint é usado pela interface e identificável no código. |

Fonte: elaboração própria.

## Conclusão e risco residual

A diferença entre as guardas administrativas e contábeis mostra onde colocar o controle. O servidor deve definir permissões de leitura de contas e moderação e verificar ambas nas rotas correspondentes. O papel contábil precisa de estado de sessão atualizado e validação de transição de entrega. O risco residual inclui abuso por operador autorizado e inconsistência em escritas concorrentes. Auditoria protegida, segregação de funções e atualização condicional reduzem esses efeitos e permitem investigar incidentes.

## 6.5 Justificativas de não aplicabilidade e guias

| Código | Justificativa |
|---|---|
| N/A 1 | S e R em entidade ou interface. Ações públicas ou de interface, sem afirmação de identidade ou autoria adicional. Para ações autenticadas, a prova e a auditoria ficam no processo servidor e em D5. |
| N/A 2 | T em ação ou requisição. O remetente já controla a entrada. A adulteração com efeito no ativo foi examinada no processo de destino, ou a entrada é apenas consulta sem mudança de estado. |
| N/A 3 | T em resposta ou conexão interna. A alteração independente da mensagem exigiria controle de host, bridge, arquivo ou memória. O efeito das entradas manipuláveis é tratado no processo e nas escritas associadas. |
| N/A 4 | I em requisição ou troca interna. Acesso direto ao transporte local, memória ou arquivo exigiria a condição excluída de comprometimento do host. Exposições mediadas pela resposta da API foram examinadas no processo e no fluxo de saída. |
| N/A 5 | I em tela ou resposta. Os dados em análise são públicos ou próprios da finalidade daquela saída. O retorno indevido identificável está vinculado à ameaça da API correspondente. |
| N/A 6 | D em tela, saída ou operação interna. O segmento não oferece entrada de carga independente. O custo é analisado na requisição e no processo que aciona a leitura, a gravação ou a resposta. |
| N/A 7 | T ou I em armazenamento. O componente é local e sem interface direta para o agente do fluxo. Alterações e acessos mediados pela aplicação são examinados nos processos que o utilizam. |
| N/A 8 | S, R ou E em processo. A ação específica é pública ou apenas repassa entrada, sem afirmar identidade, guardar prova de autoria ou decidir permissão naquele ponto. A decisão aplicável é examinada no processo servidor, com dependência do FX1. |
| N/A 9 | T, I ou D em logs. Este fluxo não fornece comando de leitura, alteração ou remoção direta em D5. A exposição identificada por dados em URL é tratada no FX2. Retenção e possibilidade de contestação são examinadas em R. |
| N/A 10 | D em processo ou estado do navegador. Uma falha restrita ao cliente afeta a sua própria sessão. Saturação da instância é analisada no servidor. Em P6, os cenários volumétricos de download estão fora do recorte. |
| N/A 11 | T ou I no estado local do navegador. Alterar a cópia local ou ler o próprio armazenamento não modifica o dado autorizado no servidor. Uso de token alheio ou excessos no conteúdo são avaliados na emissão ou na rota consumidora. |
| N/A 12 | D em entrada sem operação custosa própria neste recorte. O custo das entradas HTTP está associado ao processo e à rota de maior consumo selecionada no fluxo. |
| N/A 13 | T ou I em interface cliente. A transferência na interface representa ações do ator no próprio navegador. O efeito de entrada manipulada ou resposta indevida é avaliado na correspondente chamada HTTP. |

Guias da OWASP citados no tratamento: AUTH: Authentication Cheat Sheet; SQLI: SQL Injection Prevention Cheat Sheet; LOG: Logging Cheat Sheet; PASS: Password Storage Cheat Sheet; SESS: Session Management Cheat Sheet; SECRETS: Secrets Management Cheat Sheet; RESET: Forgot Password Cheat Sheet; AUTHZ: Authorization Cheat Sheet; MASS: Mass Assignment Cheat Sheet; ERR: Error Handling Cheat Sheet; IDOR: Insecure Direct Object Reference Prevention Cheat Sheet; DOS: Denial of Service Cheat Sheet; BIZ: Business Logic Security Cheat Sheet. Os endereços completos constam do arquivo-fonte e da série OWASP Cheat Sheets nas referências.

# 7 VISÃO CONSOLIDADA

A ordenação reúne os 25 cenários do arquivo-fonte: 18 de risco alto e sete de risco médio. Sete registros se apoiam em seis achados da M1; V5 sustenta a hipótese adicional sobre comprovantes. T-FX2-06, inicialmente plausível, foi reproduzida na M2. A injeção no login tem a maior média (9,8), seguida do papel privilegiado no cadastro (9,0). As médias e as justificativas do capítulo 6 e do ranking usam as mesmas cinco notas. Parametrizar a consulta de autenticação corrige a injeção. A autorização por função e por objeto deve ser aplicada no ponto em que cada recurso é lido ou alterado.

Quadro 37: Top 10 por média DREAD

| # | Cenário (elemento principal) | DREAD | Status |
|---|---|---|---|
| 1 | T-FX1-02 Injeção SQL na autenticação (P2) | 9,8 | T1 · V1 |
| 2 | T-FX2-06 Papel privilegiado no cadastro (P3) | 9,0 | Reproduzida na M2 |
| 3 | T-FX2-01 Resposta previsível no reset (P3) | 8,8 | T1 · V7 |
| 4 | T-FX1-04 Hash de senha no JWT (F10) | 8,6 | T1 · V2 |
| 5 | T-FX4-04 Consulta de usuários (F16) | 8,6 | Reproduzida na M2 |
| 6 | T-FX3-06 Leitura da cesta de outro titular (P4) | 8,4 | T1 · V3 |
| 7 | T-FX1-06 Chave de assinatura distribuída (P2) | 8,4 | Plausível |
| 8 | T-FX4-06 Exclusão de feedback (P5) | 8,2 | Plausível |
| 9 | T-FX1-01 Tentativas repetidas no login (P2) | 8,0 | T1 · V6 |
| 10 | T-FX3-02 Checkout de cesta alheia (P4) | 7,8 | Plausível |

Fonte: elaboração própria. T1 indica confirmação histórica na M1; M2 indica reprodução complementar em 08/11/2026.

Cada ameaça é contada uma vez pela categoria e pelo primeiro elemento do registro. Information Disclosure reúne cinco cenários; cada outra categoria, quatro. Por tipo principal, são 16 processos, 5 armazenamentos e 4 transferências de dados.

Quadro 38: Plano de mitigação por frentes

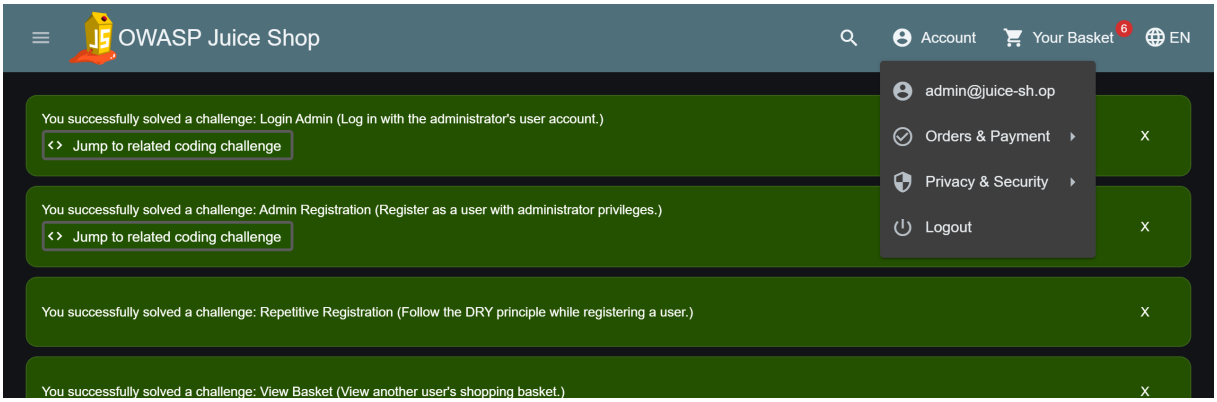
| Frente | Tratamento e critério de aceite |
|---|---|
| 1: Autenticação, emissão e segredos<br>T-FX1-02, 04 e 06 | Parametrizar consulta, restringir claims, migrar hash de senha e rotacionar chave com revogação de JWT antigo. Aceite: A entrada V1 falha. Nenhum JWT ou retorno de perfil contém hash. Chaves antigas são rejeitadas. |
| 2: Cadastro e recuperação<br>T-FX2-06, 01, 02 e 04 | Atribuir papel no servidor, substituir pergunta por recuperação de uso único e uniformizar respostas. Remover o vínculo público baseado em UserId. Aceite: Cadastro força customer. Reset não enumera contas e token de recuperação não pode ser reutilizado. |
| 3: Autorização em P4 e P5<br>T-FX4-04 e 06, T-FX3-06, 02 e 07 | Adotar política de função nas rotas privilegiadas e política de titularidade em cesta, pedido, endereço, pagamento e comprovante. Aceite: Matriz de papéis nega chamadas indevidas. Duas contas não acessam nem alteram recursos uma da outra. |
| 4: Ciclo de sessão e contenção<br>T-FX1-01 e 05, T-FX3-01, T-FX4-01, T-FX2-05 | Aplicar limites por conta e origem, expiração efetiva, revogação e validação atual de papéis. Tratar sessões e capacidade de armazenamento. Aceite: Replay após logout, expiração ou rebaixamento falha. Amostra com abuso controlado preserva operação legítima. |
| 5: Integridade e disponibilidade de pedidos<br>T-FX3-02 e 05, T-FX4-02 e 05 | Introduzir idempotência, controle de versão, quota de PDF, paginação e procedimento de compensação em falhas parciais. Aceite: Reenvio não duplica pedido. Escrita concorrente é detectada e listagens respeitam o limite. |
| 6: Auditoria e retorno de erros<br>T-FX1-03, T-FX2-03, T-FX3-03 e 04, T-FX4-03 | Centralizar eventos de autenticação, reset, compra e ações privilegiadas em trilha protegida. Remover versão e detalhes de erro do cliente. Aceite: Eventos correlacionáveis com dados mínimos. Resposta de falha sem detalhe interno. |

Fonte: elaboração própria.

# 8 VALIDAÇÃO E LIMITAÇÕES

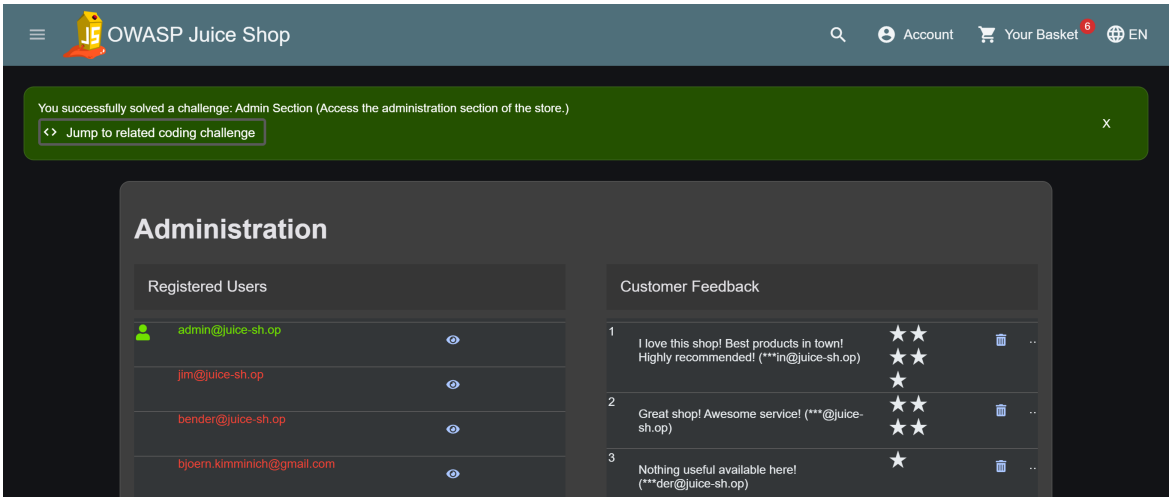
A conferência comparou as entradas dos diagramas com o código e com os pares HTTP da M1, que sustentam injeção no login, hash no JWT, leitura de cesta alheia, erro verboso, listagem em /ftp/, falhas sucessivas de autenticação e recuperação por resposta previsível. Em 8 de novembro de 2026, a equipe reimplantou a mesma imagem em 127.0.0.1:3000. Foram registrados login administrativo por injeção, hash no JWT sem o campo exp, cadastro com papel privilegiado, cesta de outro titular (200 com token; 401 sem token), listagem anônima de /ftp/ e cota de 100 no reset. O motor de desafios registrou Login Admin, Admin Registration, View Basket e Error Handling. A ausência de exp foi observada nos tokens; a aceitação temporal por cada rota ainda depende de ensaio.

Figura 7: Sessão de administrador obtida por injeção SQL (reprodução M2)




Fonte: elaboração própria.

Figura 8: Painel /#/administration com a lista de usuários (reprodução M2)




Fonte: elaboração própria.

Limitações. As evidências históricas foram complementadas por verificações HTTP diretas em 08/11/2026. Foram executados testes de autenticação, cadastro, recuperação, autorização de cesta, listagem de arquivos e consulta de usuários com papéis distintos. Os resultados estão em REVISAO_HTTP_FINAL.json. Os ensaios usaram baixo volume e contas temporárias; não mediram esgotamento, concorrência ou validade temporal em todas as rotas. A revisão documental final está concluída. Os controles e riscos residuais descritos representam o tratamento proposto, cuja eficácia exige implantação.

# 9 CONCLUSÃO

A modelagem localizou quatro funções em que uma decisão do servidor tem efeito direto sobre conta, cesta, pedido ou operação privilegiada. As evidências concentram-se em pontos diferentes: a injeção altera a consulta que determina a identidade; o hash decorre da serialização da conta no JWT; a leitura de cesta alheia ocorre depois que a sessão foi aceita; a recuperação combina pergunta consultável com prova previsível. A prioridade é corrigir a autenticação, reduzir os dados incluídos no JWT e definir o papel das novas contas no servidor, estendendo o controle de acesso às APIs administrativas, às referências do checkout e à entrega de comprovantes. Os critérios de aceite permitem verificar cada medida com contas de teste. A análise mostrou a necessidade de verificar a titularidade do recurso após a validação da sessão.

Arquivo-fonte do modelo e evidências: https://github.com/diegof-d2fs/m2-seg-system-diegos/tree/main/trabalho2. O modelo editável é trabalho2/modelo/DFD_Juice_Shop.drawio; as notas e justificativas estão em modelo_ameacas.json. A revisão estrutural foi executada com validar_modelo.py.

# REFERÊNCIAS


ALVES, Luis Fernando et al. Modelagem de ameaças com STRIDE e DREAD: uma análise preliminar aplicada a um sistema IoT. In: ESCOLA REGIONAL DE ENGENHARIA DE SOFTWARE, 8., 2024. Anais [...]. Porto Alegre: Sociedade Brasileira de Computação, 2024. p. 218-227. DOI 10.5753/eres.2024.4319. Disponível em: https://sol.sbc.org.br/index.php/eres/article/download/31855/31657/. Acesso em: 8 nov. 2026.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 8 nov. 2026.

CARNEIRO, Cinara Gomes de Melo; KUDO, Taciana Novo; BULCÃO NETO, Renato de Freitas. Um método para transformação de requisitos legais em padrões de requisitos de software: um estudo com a LGPD. In: CONGRESSO IBERO-AMERICANO EM ENGENHARIA DE SOFTWARE, 27., 2024, Curitiba. Anais [...]. Porto Alegre: Sociedade Brasileira de Computação, 2024. p. 348-355. DOI 10.5753/cibse.2024.28460. Disponível em: https://sol.sbc.org.br/index.php/cibse/article/download/28460/28270/. Acesso em: 8 nov. 2026.

DOCKER. Docker Engine networking. Seções Bridge network driver e Port publishing and mapping. [S. l.]: Docker, [s. d.]. Disponível em: https://docs.docker.com/engine/network/drivers/bridge/ e https://docs.docker.com/engine/network/port-publishing/. Acesso em: 8 nov. 2026.

HERNAN, Shawn et al. Uncover security design flaws using the STRIDE approach. MSDN Magazine, nov. 2006. Disponível em: https://learn.microsoft.com/en-us/archive/msdn-magazine/2006/november/uncover-security-design-flaws-using-the-stride-approach. Acesso em: 8 nov. 2026.

MANADHATA, Pratyusa K.; WING, Jeannette M. An attack surface metric. IEEE Transactions on Software Engineering, v. 37, n. 3, p. 371-386, 2011. DOI 10.1109/TSE.2010.60. Disponível em: https://manadhata.github.io/pdf/tse11.pdf. Acesso em: 8 nov. 2026.

MEIER, J. D. et al. Threat modeling. In: MEIER, J. D. et al. Improving web application security: threats and countermeasures. [S. l.]: Microsoft, 2003. cap. 3. Disponível em: https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648644(v=pandp.10). Acesso em: 8 nov. 2026.

MITRE. Common Weakness Enumeration. [S. l.]: MITRE, [s. d.]. Disponível em: https://cwe.mitre.org/. Acesso em: 8 nov. 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Guide for conducting risk assessments. Gaithersburg: NIST, 2012. NIST SP 800-30, rev. 1. DOI 10.6028/NIST.SP.800-30r1. Disponível em: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf. Acesso em: 8 nov. 2026.

OWASP FOUNDATION. OWASP Cheat Sheet Series. [S. l.]: OWASP Foundation, [s. d.]. Disponível em: https://cheatsheetseries.owasp.org/. Acesso em: 8 nov. 2026.

OWASP FOUNDATION. OWASP Top 10:2021. [S. l.]: OWASP Foundation, 2021. Disponível em: https://owasp.org/Top10/2021/. Acesso em: 8 nov. 2026.

OWASP FOUNDATION. OWASP Application Security Verification Standard. Versão 5.0.0. [S. l.]: OWASP Foundation, 2025. Disponível em: https://github.com/OWASP/ASVS/releases/tag/v5.0.0. Acesso em: 8 nov. 2026.

OWASP JUICE SHOP. OWASP Juice Shop. Código-fonte e testes da versão v20.2.0. [S. l.]: OWASP, 2026. Disponível em: https://github.com/juice-shop/juice-shop/tree/v20.2.0. Acesso em: 8 nov. 2026.

SCANDARIATO, Riccardo; WUYTS, Kim; JOOSEN, Wouter. A descriptive study of Microsoft's threat modeling technique. Requirements Engineering, v. 20, n. 2, p. 163-180, 2015. DOI 10.1007/s00766-013-0195-2. Disponível em: https://link.springer.com/article/10.1007/s00766-013-0195-2. Acesso em: 8 nov. 2026.

SHOSTACK, Adam. Threat modeling: designing for security. Indianapolis: Wiley, 2014. Disponível em: https://www.wiley.com/en-us/threat-modeling-designing-for-security-p-9781118809990. Acesso em: 8 nov. 2026.

SILVA, Diego Fonseca da et al. Case prático 1: avaliação de vulnerabilidades em aplicação web. Itajaí: Universidade do Vale do Itajaí, 2026. Relatório de disciplina, configuração e evidências do laboratório. Disponível em: https://github.com/diisilva/m1-seg-system-diegos. Acesso em: 8 nov. 2026.

SOUPPAYA, Murugiah; SCARFONE, Karen; DODSON, Donna. Secure Software Development Framework (SSDF) version 1.1: recommendations for mitigating the risk of software vulnerabilities. Gaithersburg: NIST, 2022. NIST SP 800-218. DOI 10.6028/NIST.SP.800-218. Disponível em: https://csrc.nist.gov/pubs/sp/800/218/final. Acesso em: 8 nov. 2026.

TUMA, Katja; ÇALIKLI, Gül; SCANDARIATO, Riccardo. Threat analysis of software systems: a systematic literature review. Journal of Systems and Software, v. 144, p. 275-294, 2018. DOI 10.1016/j.jss.2018.06.073. Disponível em: https://www.sciencedirect.com/science/article/pii/S0164121218301304. Acesso em: 8 nov. 2026.